WAECS

Web-based Applications and E-Commerce Security

EMMANUEL ATEJI
33043543

Table of Contents

Executive Summary 3

Introduction 4

Evaluation of the cloud server's security. 6

- Tools and Terminology 6
- Evaluation Methodology 8
- Assessing the Cloud Server Network Settings 9
- Results 10
- Analysis 12

Recommendations to secure the server for DevOps deployment. 22

- The impact of Notable attacks on cloud security 22
- Recommendations for the Cloud Server 24
- DevOps Deployment Security Recommendations 27

Implementation of technical security recommendations 30

- System Updates and Upgrades 30
- Apache Web Server Hardening 31
- Security Headers Implementation 37
- PHP Hardening 38
- Directory browsing and Indexing. 39
- jQuery Library Update 40
- Encrypted Data Transmission 41
- Password Management 43
- SSH Hardening 44
- Network Security 46
- Systemctl Hardening 50
- Server Header Information 51
- Additional Security Implementation 52
- Secure Remote Access 52
- Installation of Anti-virus 53

Demonstration of security 55

Conclusion 59

References.....60
Appendix.....65

Executive Summary

SoftCorp conducted a comprehensive security assessment of its cloud server using industry-standard vulnerability scanning tools. The initial scans revealed critical weaknesses, including default credentials, outdated software, and misconfigurations. A set of prioritized technical security recommendations were developed and implemented, covering system updates, server hardening, security header implementation, encryption, password management, and additional security measures.

Final vulnerability scans confirmed the effectiveness of the implemented security controls, with no critical or high-severity vulnerabilities detected. However, the lack of Anti-CSRF protection remains an area for improvement. The security assessment and subsequent hardening have significantly improved the cloud server's security posture, aligning it with industry best practices and reducing the risk of security incidents. SoftCorp is now better prepared to securely deploy the server in a DevOps environment, with a commitment to continuous improvement.

Introduction

In today's rapidly evolving digital landscape, organizations are increasingly adopting cloud technologies and DevOps practices to enhance agility, scalability, and efficiency. Cloud computing offers three main service models: Infrastructure as a Service (IaaS), Platform as a Service (PaaS), and Software as a Service (SaaS) (Goyal, 2014). IaaS provides virtualized computing resources, PaaS offers a platform for developing and deploying applications, and SaaS delivers software applications over the internet (Aldossary & Allen, 2016). The choice of cloud service model depends on the organization's requirements and the level of control they need over the underlying infrastructure.

SoftCorp, a company providing management services to other organizations, has recognized the benefits of embracing a DevOps approach and aims to leverage its advantages by deploying a key cloud server for storing and accessing files by their employees. The cloud server being assessed in this report likely falls under the IaaS model, as SoftCorp maintains control over the operating system, storage, and deployed applications (Grance, 2018). As part of this initiative, SoftCorp has engaged in a comprehensive security assessment to evaluate the current security posture of the server and identify potential vulnerabilities that could be exploited by malicious actors.

The purpose of this report is to present the findings of the security assessment conducted on SoftCorp's cloud server (IP address: 30.30.0.100) and provide recommendations to enhance its security before deployment in a DevOps environment. The assessment focuses on identifying vulnerabilities, misconfigurations, and weaknesses that could compromise the confidentiality, integrity, and availability of the server and its stored data.

The report will begin by outlining the evaluation methodology, which includes the use of industry-standard vulnerability scanning tools. These tools were selected based on their comprehensive scanning capabilities and ability to identify a wide range of security issues (IMohaidat & Al-Helali, 2024).

Following the evaluation, the report will provide a critical analysis of the identified vulnerabilities, highlighting their potential impact on the server's security and the risks associated with deploying the server in its current state. Based on this analysis, prioritized recommendations will be presented to address the identified issues and strengthen the server's security posture (Scarfone et al., 2008).

The report will then detail the implementation of the technical security recommendations, outlining the specific steps taken to remediate the vulnerabilities and harden the server's configuration. This section will demonstrate SoftCorp's commitment to ensuring the security of its systems and data.

Finally, the report will provide evidence of the achieved security level, demonstrating that the implemented measures have effectively mitigated the identified risks. This will instill confidence in SoftCorp's ability to securely deploy the cloud server in a DevOps environment.

By following the recommendations and implementing the necessary security controls, SoftCorp can establish a robust foundation for its DevOps practices, enabling the organization to reap the benefits of agility and innovation while maintaining a strong security posture.

Evaluation of the cloud server's security.

As organizations continue to adopt cloud technologies and DevOps practices, it is crucial to ensure the security of cloud infrastructure. SoftCorp, a company providing management services to other organizations, has engaged in a comprehensive security assessment of its cloud server before deploying it in a DevOps environment.

The adoption of cloud computing has introduced new security challenges and risks that must be addressed. Some of the emerging threats and risks in cloud computing include:

1. Data breaches: Misconfigured cloud storage, weak access controls, and vulnerabilities in cloud applications can lead to unauthorized access and data breaches (Jouini & Rabai, 2019).
2. Insider threats: Malicious insiders or compromised user accounts can pose significant risks to the security of cloud resources and data (Liu et al., 2020).
3. Insecure APIs: Poorly secured APIs can be exploited by attackers to gain unauthorized access, manipulate data, or disrupt cloud operations (Basu et al., 2019).
4. Crypto jacking: Attackers may exploit vulnerabilities or misconfigurations to hijack cloud resources for unauthorized cryptocurrency mining (Singh et al., 2019).
5. Compliance and regulatory risks: Failure to meet compliance and regulatory requirements can result in legal and financial consequences (Coppolino et al., 2017).

Considering these emerging threats and risks, it is essential to conduct a thorough security evaluation of SoftCorp's cloud server to identify potential vulnerabilities, misconfigurations, and weaknesses that could be exploited by malicious actors.

Tools and Terminology

The security evaluation of SoftCorp's cloud server was conducted using a combination of industry-standard vulnerability scanning tools. These tools were selected based on their comprehensive scanning capabilities and ability to identify a wide range of security issues (Toyin, 2023). The following tools and terminology were employed in this assessment:

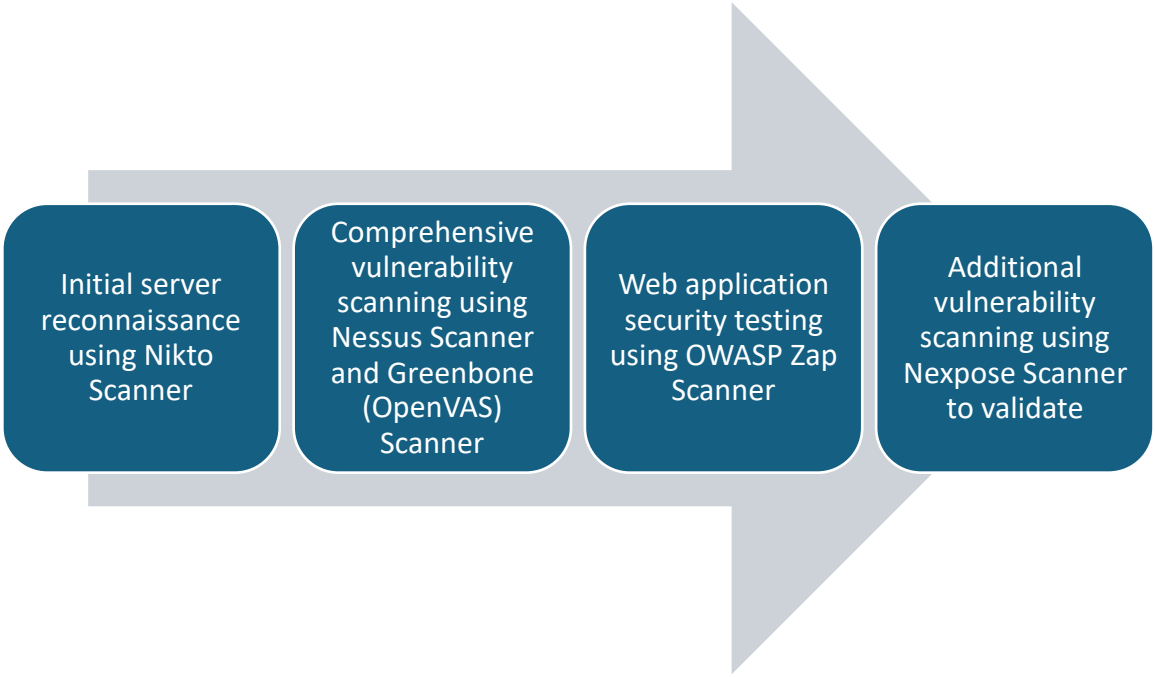
Tools	Terminology
Virtual Machine	VMWare VM is a virtualization software that allows running multiple operating systems on a single physical machine. It creates isolated virtual environments called virtual machines (VMs) where different operating systems can be installed and run simultaneously on the same hardware.
Linux Ubuntu	Linux Ubuntu is a popular open-source operating system based on the Debian Linux distribution. It is known for its user-friendly interface, stability, and extensive community support. Ubuntu follows a regular release cycle and is widely used for both desktop and server environments.
Ubuntu Terminal	The Ubuntu Terminal, also known as the command-line interface (CLI), is a text-based interface for interacting with the Ubuntu operating system. It allows users to execute commands, run scripts, and perform various system administration tasks. The terminal provides powerful control and flexibility for managing the operating system.
Cloud Server	A cloud server is a virtual server that runs on a cloud computing platform, providing computing resources over the internet. It offers scalability, flexibility, and on-demand access to resources. Cloud servers can be easily provisioned, configured, and managed through web-based interfaces or APIs.
Nessus Scanner	Nessus is a popular vulnerability scanning tool developed by Tenable. It is used to identify security vulnerabilities and misconfigurations in computer systems, networks, and applications. Nessus performs comprehensive scans and provides detailed reports on discovered vulnerabilities, along with recommendations for remediation.
Greenbone (OpenVAS) Scanner	Greenbone, formerly known as OpenVAS (Open Vulnerability Assessment System), is an open-source vulnerability scanning and management solution. It provides a comprehensive set of tools for network security assessments, including vulnerability scanning, vulnerability management, and compliance checks. Greenbone offers a centralized web interface for managing scans and generating reports.
Nexpose Scanner	Nexpose is a vulnerability management solution developed by Rapid7. It automates the process of vulnerability detection, assessment, and remediation. Nexpose conducts in-depth scans of networks, systems, and web applications to identify security weaknesses. It provides prioritized remediation guidance and

	integrates with other security tools for a comprehensive vulnerability management workflow.
OWASP ZAP Scanner	OWASP ZAP (Zed Attack Proxy) is an open-source web application security scanner developed by the Open Web Application Security Project (OWASP). It is designed to help identify vulnerabilities in web applications during the development and testing phases. ZAP provides features such as intercepting proxy, automated scanners, and various attack modules to assess the security of web applications.
Nikto Scanner	Nikto is an open-source web server scanner that performs comprehensive tests against web servers for various security issues. It checks for outdated server software, dangerous files, and misconfigurations. Nikto is known for its extensive database of vulnerabilities and its ability to detect security problems in web servers and web applications.

Evaluation Methodology

The security evaluation was conducted using the following methodology:

1. Initial server reconnaissance using Nikto Scanner to identify common vulnerabilities and misconfigurations.
2. Comprehensive vulnerability scanning using Nessus Scanner and Greenbone (OpenVAS) Scanner to detect known vulnerabilities and weaknesses.
3. Web application security testing using OWASP Zap Scanner to identify vulnerabilities specific to the server's web applications.
4. Additional vulnerability scanning using Nexpose Scanner to validate findings and identify any additional issues.



Assessing the Cloud Server Network Settings

The 'ip a' command is used to display the network interface configuration and IP addresses assigned to an Ubuntu Cloud Server. It provides information about the server's network settings, including the IP address, subnet mask, and network interfaces.

```
admin@waecs:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:51:d9:7d brd ff:ff:ff:ff:ff:ff
    altname enp2s1
    inet 192.168.216.149/24 metric 100 brd 192.168.216.255 scope global dynamic ens33
       valid_lft 1129sec preferred_lft 1129sec
    inet6 fe80::20c:29ff:fe51:d97d/64 scope link
       valid_lft forever preferred_lft forever
3: ens34: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:51:d9:87 brd ff:ff:ff:ff:ff:ff
    altname enp2s2
    inet 30.30.0.100/24 brd 30.30.0.255 scope global ens34
       valid_lft forever preferred_lft forever
    inet6 fe80::20c:29ff:fe51:d987/64 scope link
       valid_lft forever preferred_lft forever
admin@waecs:~$ _
```

Figure shows the ip a of the cloud server after configuration of network settings.

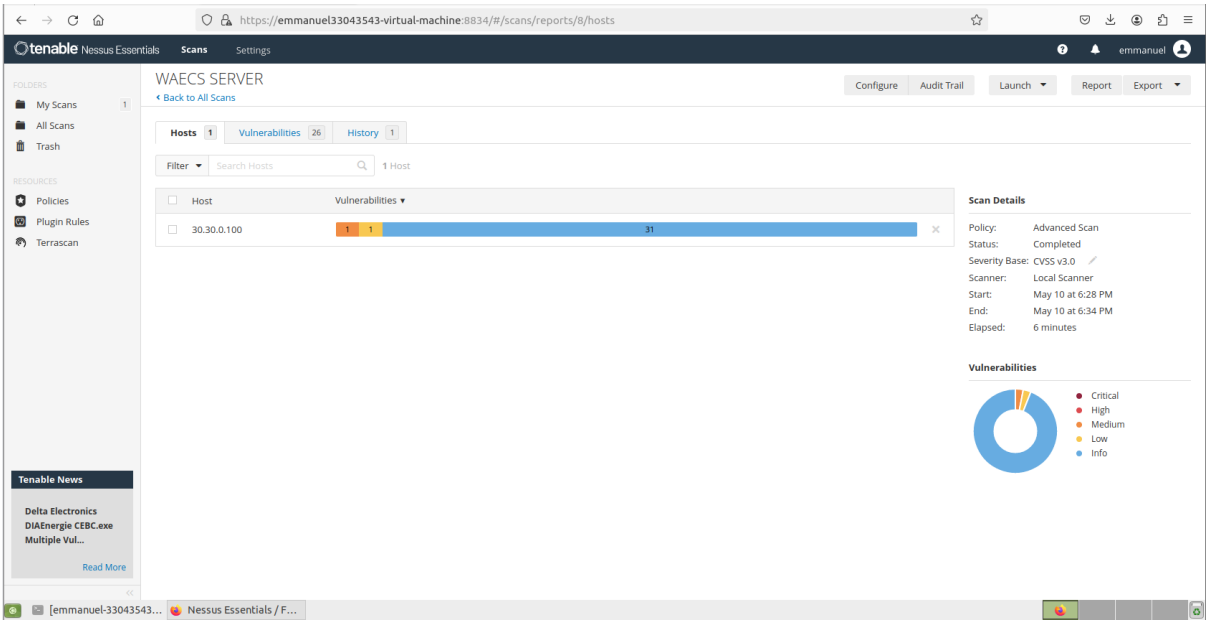
Results

The security evaluation of SoftCorp's cloud server was performed using a combination of industry-standard vulnerability scanning tools. Each tool was selected for its specific capabilities and strengths in identifying vulnerabilities and misconfigurations. The initial results obtained from each scanner provide valuable insights into the server's security posture and highlight areas that require attention. See appendix for the full scan reports.

NIKTO INITIAL SCAN RESULT

```
emmanuel-33043543@emmanuel33043543-virtual-machine: ~
File  Edit  View  Search  Terminal  Help
emmanuel-33043543@emmanuel33043543-virtual-machine:~$ nikto -h 30.30.0.100
- Nikto v2.1.5
---------------------------------------------------------------------------
+ Target IP:          30.30.0.100
+ Target Hostname:    30.30.0.100
+ Target Port:        80
+ Start Time:         2024-05-10 18:55:22 (GMT1)
---------------------------------------------------------------------------
+ Server: Apache/2.4.52 (Ubuntu)
+ Server leaks inodes via ETags, header found with file /, fields: 0x3b6d 0x60e30f02203ef
+ The anti-clickjacking X-Frame-Options header is not present.
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ IP address found in the 'location' header. The IP is "127.0.1.1".
+ OSVDB-630: IIS may reveal its internal or real IP in the Location header via a request to the /images directory. The value is "http://127.0.1.1/images/".
+ Allowed HTTP Methods: GET, POST, OPTIONS, HEAD
+ OSVDB-3233: /phpinfo.php: Contains PHP configuration information
+ OSVDB-3268: /images/: Directory indexing found.
+ OSVDB-3268: /images/?pattern=/etc/*&sort=name: Directory indexing found.
+ 6544 items checked: 0 error(s) and 8 item(s) reported on remote host
+ End Time:           2024-05-10 18:55:36 (GMT1) (14 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
emmanuel-33043543@emmanuel33043543-virtual-machine:~$
```

NESSUS INITIAL SCAN RESULT



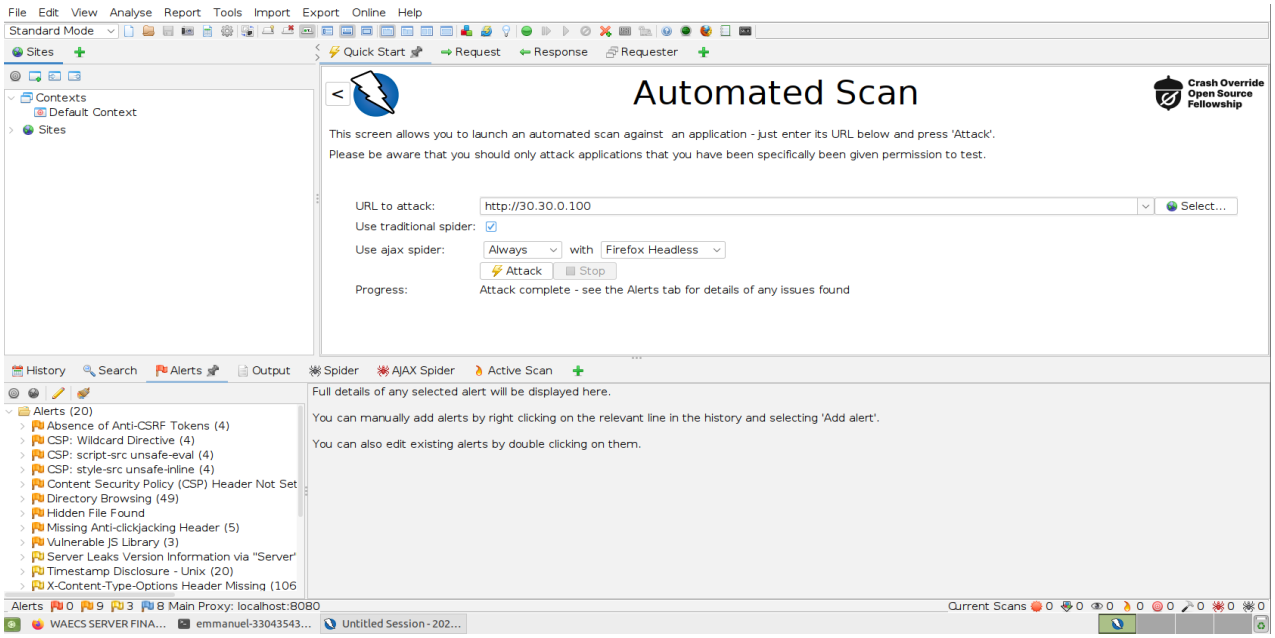
GREENBONE (OpenVAS) INITIAL SCAN RESULT

Information | Results (7 of 45) | Hosts (1 of 1) | Ports (2 of 2) | Applications (5 of 5) | Operating Systems (1 of 1) | CVEs (3 of 3) | Closed CVEs (0 of 0) | TLS Certificates (0 of 0) | Error Messages (1 of 1) | User Tags (0)

Vulnerability		Severity ▼	QoD	Host IP	Name	Location
HTTP Brute Force Logins With Default Credentials Reporting		7.5 (High)	95 %	30.30.0.100		80/tcp
phpinfo() Output Reporting (HTTP)		5.3 (Medium)	80 %	30.30.0.100		80/tcp
ownCloud/Nextcloud Unprotected Data Directory		5.0 (Medium)	98 %	30.30.0.100		80/tcp
Cleartext Transmission of Sensitive Information via HTTP		4.8 (Medium)	80 %	30.30.0.100		80/tcp
Weak MAC Algorithm(s) Supported (SSH)		2.6 (Low)	80 %	30.30.0.100		22/tcp
TCP Timestamps Information Disclosure		2.6 (Low)	80 %	30.30.0.100		general/tcp
ICMP Timestamp Reply Information Disclosure		2.1 (Low)	80 %	30.30.0.100		general/icmp

(Applied filter: apply_overrides=0 levels=hml rows=100 min_qod=70 first=1 sort-reverse=severity)

OWASP ZAP INITIAL SCAN RESULT



NEXPOSE INITIAL SCAN RESULT

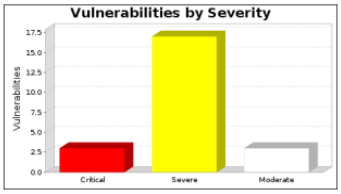
Audit Report

1. Executive Summary

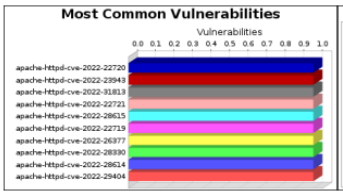
This report represents a security audit performed by InsightVM from Rapid7 LLC. It contains confidential information about the state of your network. Access to this information by unauthorized personnel may allow them to compromise your network.

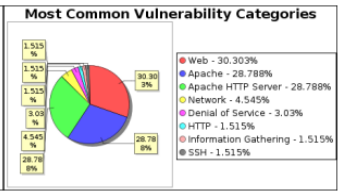
Site Name	Start Time	End Time	Total Time	Status
WAECS SERVER SCAN	May 10, 2024 13:22, EDT	May 10, 2024 13:24, EDT	2 minutes	Success

There is not enough historical data to display risk trend.
The audit was performed on one system which was found to be active and was scanned.



There were 23 vulnerabilities found during this scan. Of these, 3 were critical vulnerabilities. Critical vulnerabilities require immediate attention. They are relatively easy for attackers to exploit and may provide them with full control of the affected systems. 17 vulnerabilities were severe. Severe vulnerabilities are often harder to exploit and may not provide the same access to affected systems. There were 3 moderate vulnerabilities discovered. These often provide information to attackers that may assist them in mounting subsequent attacks on your network. These should also be fixed in a timely manner, but are not as urgent as the other vulnerabilities.



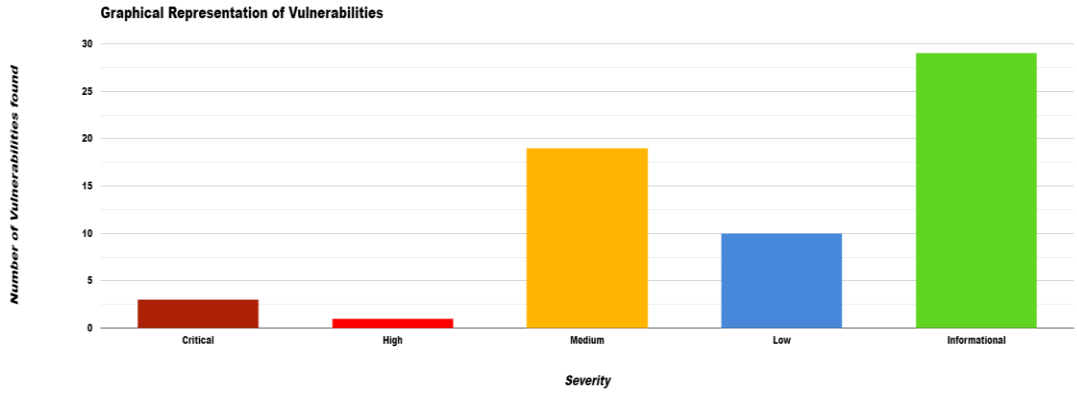


There were 1 occurrences of the apache-httpd-cve-2022-22720, apache-httpd-cve-2022-23943, apache-httpd-cve-2022-31813, apache-httpd-cve-2022-22721, apache-httpd-cve-2022-28615, apache-httpd-cve-2022-22719, apache-httpd-cve-2022-26377, apache-httpd-cve-2022-28330, apache-httpd-cve-2022-28614 and apache-httpd-cve-2022-29404 vulnerabilities, making them the most common vulnerabilities. There were 20 vulnerability instances in the Web category, making it the most common vulnerability category.

Analysis

After the initial scan, a total of 35 vulnerabilities were found. The SoftCorp cloud server's security assessment revealed critical weaknesses through a comprehensive analysis of its configuration using various vulnerability scanning tools. Below is the summary and a graphical representation of the vulnerabilities discovered.

3	1	19	10	29
Critical	**High**	**Medium**	**Low**	**Informational**



Vulnerability Name	Brief Description of the Vulnerability	Severity Rating	CVSS Rating (v2.0*, v3.0)	Recommendation
Critical Severity Vulnerabilities				
Apache HTTPD: HTTP request smuggling vulnerability in Apache HTTP Server 2.4.52 and earlier.	Apache HTTP Server fails to close inbound connection when errors are encountered discarding the request body, exposing the server to HTTP request smuggling.	Critical	7.5	Upgrade to Apache HTTP Server 2.4.53 or newer and apply security patches.
Apache HTTPD: mod_sed: Read/write beyond bounds.	Out-of-bounds write vulnerability in mod_sed allows an attacker to overwrite heap memory with possibly attacker-provided data.	Critical	7.5	Upgrade to Apache HTTP Server 2.4.53 or newer, apply security patches, and disable mod_sed if not needed.
Apache HTTPD: mod_proxy X-	The X-Forwarded-* headers may not be	Critical		Upgrade to Apache HTTP Server 2.4.54

Forwarded-For dropped by hop-by-hop mechanism.	sent to the origin server, allowing bypass of IP-based authentication.			or newer, apply security patches, and ensure proper mod_proxy configuration.
High Severity Vulnerabilities				
HTTP Brute Force Logins With Default Credentials Reporting	It was possible to login into the remote Web Application using default admin credentials (admin:password). This could allow unauthorized access to sensitive information or system configuration.	High	7.5	Change default credentials to strong, unique passwords and implement account lockout policies.
Medium Severity Vulnerabilities				
phpinfo() Output Reporting (HTTP)	The phpinfo() function discloses potentially sensitive information such as the PHP version, web server version, system version, and web server root directory.	Medium	5.3	Disable or remove phpinfo() files in production and ensure proper access controls.
ownCloud/Nextcloud Unprotected Data Directory	The ownCloud/Nextcloud data directory is exposed and unprotected, allowing unauthenticated access to enumerate and access sensitive user data and files.	Medium	5.0	Protect the data directory with appropriate access controls and permissions.

Cleartext Transmission of Sensitive Information via HTTP	The application transmits sensitive information like usernames and passwords in cleartext over HTTP instead of using encrypted HTTPS, enabling potential eavesdropping.	Medium	4.8	Enforce HTTPS for all sensitive data transmission, use strong encryption, and implement HSTS.
CSP: Wildcard Directive	Content Security Policy (CSP) headers use wildcard (*) directives or allow unsafe sources, weakening the CSP protections.	Medium	4.9	Review and refine CSP headers, remove wildcard directives, and specify trusted sources explicitly.
CSP: script-src unsafe-eval	Content Security Policy (CSP) headers allow the use of 'unsafe-eval' in script sources, which is risky as it allows executing code from strings.	Medium	4.8	Remove 'unsafe-eval' from CSP script-src policy and refactor code to eliminate its need.
CSP: style-src unsafe-inline	Content Security Policy (CSP) headers allow the use of 'unsafe-inline' in style sources, which is not recommended as it allows inline styles.	Medium	4.8	Remove 'unsafe-inline' from CSP style-src policy and externalize inline styles.
Content Security Policy (CSP) Header Not Set	Some pages do not have a Content Security Policy (CSP) header set, which could allow various attacks if no	Medium	4.9	Implement a strong CSP header for all pages with appropriate directives.

	other protections are in place.			
Directory Browsing	Directory listings are enabled on the web server, which can expose sensitive files and information.	Medium	4.8	Disable directory browsing and ensure proper access controls for sensitive directories and files.
Hidden File Found	A hidden file phpinfo.php was found which exposes sensitive system information.	Medium	4.8	Remove or protect hidden files exposing sensitive information.
Missing Anti-clickjacking Header	The X-Frame-Options or CSP frame-ancestors header is not set, increasing the risk of Clickjacking attacks.	Medium	4.8	Implement X-Frame-Options or CSP frame-ancestors header to prevent clickjacking.
Vulnerable JS Library	Outdated and vulnerable JavaScript libraries like jQuery are used which have known security issues.	Medium	5.3	Update vulnerable JavaScript libraries to the latest versions with security fixes.
JQuery 1.2 < 3.5.0 Multiple XSS	The jQuery library version used is vulnerable to multiple Cross-Site Scripting (XSS) issues.	Medium	6.1	Upgrade jQuery to a version higher than 3.5.0 and keep it updated.
Absence of Anti-CSRF Tokens	No Anti-CSRF tokens were found in HTML submission forms. This could allow Cross-Site Request Forgery (CSRF) attacks.	Medium	6.0	Implement Anti-CSRF tokens in all forms performing sensitive actions.

Directory Indexing (OSVDB-630/OSVDB-3233)	IIS may reveal the web root via a request to the /images directory. Directory indexing could expose sensitive file and directory information.	Medium		Disable directory indexing in the IIS configuration and ensure proper access controls.
Directory Indexing (OSVDB-3268)	Directory indexing is enabled for /images/ and /images/?pattern=/etc/*&sort=name, which could allow attackers to discover and access sensitive files.	Medium	5.5	Disable directory indexing for the specified directories and ensure proper access controls.
HTTP OPTIONS Method Enabled	Web servers that respond to the OPTIONS HTTP method expose the supported methods, aiding attackers in narrowing down their approach.	Medium	5.0*	Disable the HTTP OPTIONS method if not required or restrict the information returned.
Apache HTTP Server Vulnerabilities	Multiple vulnerabilities in Apache HTTP Server allowing request smuggling, memory corruption, DoS, and information disclosure.	Medium	5.3	Upgrade to the latest stable version, apply security patches, and follow Apache security best practices.
SSH Weak Message Authentication Code Algorithms	The SSH server supports cryptographically weak HMAC algorithms including MD5 or 96-bit algorithms.	Medium	5.0	Disable weak HMAC algorithms in SSH configuration and use strong ones like SHA-256/512.
Low Severity Vulnerabilities				

TCP Timestamps Information Disclosure	The host implements TCP timestamps which could allow an attacker to compute the system uptime.	Low	2.6	Disable TCP timestamps if not required for network functionality.
Weak MAC Algorithm(s) Supported (SSH)	The remote SSH server is configured to allow weak MAC algorithms like umac-64-etm@openssh.com and umac-64@openssh.com.	Low	2.6	Disable weak MAC algorithms in SSH configuration and use strong ones like HMAC-SHA2-256/512.
ICMP Timestamp Reply Information Disclosure	The remote host responded to an ICMP timestamp request. This information could theoretically be used to exploit weak time-based random number generators in other services.	Low	2.1	Block ICMP timestamp requests and disable ICMP timestamp responses if not needed.
Server Leaks Version Information via "Server" HTTP Response Header Field	The web server leaks version details via the Server HTTP header, allowing attackers to find specific exploits.	Low	2.6	Minimize information disclosed in the Server header or disable it if not required.
Timestamp Disclosure - Unix	The application discloses UNIX timestamps which could be useful for further attacks.	Low		Review code and remove unnecessary timestamp disclosures or obfuscate them.

X-Content-Type-Options Header Missing.	The X-Content-Type-Options header is not set, which could lead to MIME type confusion attacks in older browsers.	Low	2.5	Implement the X-Content-Type-Options header with "nosniff" value.
Internal IP Address Disclosed.	The internal IP address 127.0.1.1 was found in the 'Location' header, which could reveal internal network information.	Low	2.9	Review code and configuration to remove any internal IP address disclosures.
ICMP Timestamp Request Remote Date Disclosure	The host responds to ICMP timestamp requests, which could allow an attacker to discover the system's clock state.	Low	2.1	Block ICMP timestamp requests and disable ICMP timestamp responses if not needed.

After conducting security assessment using various tools such as Greenbone (OpenVAS), OWASP ZAP, Nexpose, Nessus, and Nikto, the following significant vulnerabilities and misconfigurations were identified within Softcorp's cloud server: The key findings include:

1. **Default Credentials:**

    - Greenbone (OpenVAS) discovered that it was possible to log into the remote web application using default credentials (admin:password). This poses a high risk as attackers could gain unauthorized access to sensitive information and system configuration.

2. **Apache HTTP Server Vulnerabilities:**

    - NEXPOSE identified multiple critical and severe vulnerabilities in the Apache HTTP Server 2.4.52, including:

        ✓ CVE-2022-22720: HTTP request smuggling vulnerability

        ✓ CVE-2022-22721: Possible buffer overflow

- ✓ CVE-2022-23943: Mod_sed read/write beyond bounds
- ✓ CVE-2022-28615: Read beyond bounds in ap_strcmp_match()
- ✓ CVE-2023-25690: HTTP request splitting with mod_rewrite and mod_proxy.

These vulnerabilities could allow attackers to compromise the server, disclose sensitive information, or cause a denial of service.

3. **OpenSSH Weak MAC Algorithms:**
   - Greenbone (OpenVAS) detected that the SSH server supports weak Message Authentication Code (MAC) algorithms like umac-64. This could allow attackers to impersonate servers or clients and potentially gain unauthorized access.
4. **Sensitive Information Disclosure:**
   - OWASP ZAP identified a phpinfo() file that discloses potentially sensitive information about the PHP configuration and server.
   - Nikto found that the server leaks version information via the "Server" HTTP response header, which could help attackers identify exploitable vulnerabilities.
5. **Directory Listing Enabled:**
   - OWASP ZAP discovered that directory listing is enabled on the web server, allowing attackers to enumerate files and directories, potentially revealing sensitive information or hidden functionality.
6. **Absence of Security Headers:**
   - OWASP ZAP reported that several security headers are missing or misconfigured, such as:

   - ✓ Content Security Policy (CSP) header not set or using weak directives
   - ✓ X-Frame-Options header missing, exposing the application to clickjacking attacks
   - ✓ X-Content-Type-Options header not set, allowing MIME sniffing attacks
7. **Vulnerable JavaScript Library:**
   - OWASP ZAP detected that the application uses a vulnerable version of the jQuery library (< 3.5.0), which is susceptible to cross-site scripting (XSS) attacks.

8. **Unprotected ownCloud/Nextcloud data directory:**

    - Greenbone (OpenVAS) found that the ownCloud/Nextcloud data directory is unprotected, allowing unauthenticated access to user files and sensitive data.

9. **Cleartext Transmission of Sensitive Information (Greenbone OpenVAS):**

    - The remote host transmits sensitive information (e.g., usernames, passwords) in cleartext over HTTP.

The presence of these vulnerabilities and misconfigurations highlights the urgent need for SoftCorp to prioritize the security hardening of their cloud server. By addressing these critical issues, SoftCorp can significantly reduce the risk of unauthorized access, data breaches, and other security incidents, ensuring the confidentiality, integrity, and availability of their sensitive data and systems.

The following sections will provide specific recommendations and implementation details to guide the remediation process, enabling SoftCorp to strengthen the security of their cloud server and align with industry best practices and standards.

Recommendations to secure the server for DevOps deployment.

The impact of Notable attacks on cloud security

The security evaluation of SoftCorp's cloud server revealed several vulnerabilities and misconfigurations that could be exploited by significant issues affecting cloud security:

Examples of these attacks include:

Attack type	Description
Denial-of-Service (DoS) and Distributed Denial-of-Service (DDoS) Attacks	- Aim to overwhelm cloud resources and make them unavailable to legitimate users (Somani et al., 2017). - Attackers flood the cloud infrastructure with a massive amount of traffic or requests, causing service disruption (Osanaiye et al., 2016). - These attacks can be launched from multiple compromised devices (botnets) to amplify their impact.
Injection Attacks	- The Nessus and Owasp Zap scans revealed that the server's web application is susceptible to SQL injection and cross-site scripting (XSS) attacks. - Injection attacks, such as SQL injection and cross-site scripting (XSS), target vulnerabilities in cloud applications (Gupta & Gupta, 2015). - Attackers inject malicious code or commands into the application's input fields to gain unauthorized access, manipulate data, or steal sensitive information (Halfond et al., 2006). - Proper input validation and sanitization techniques should be implemented to mitigate injection attacks.

Port Scanning	- Port scanning is a reconnaissance technique used by attackers to identify open ports and services running on cloud instances (Bou-Harb et al., 2014). - Attackers use automated tools to scan a range of IP addresses and ports to discover potential entry points for attacks. - Cloud providers usually have built-in mechanisms to detect and prevent excessive port scanning activities (Buckbee, 2022)
Man-in-the-Middle (MITM) Attacks	- MITM attacks occur when an attacker intercepts and alters the communication between two parties in the cloud (Conti et al., 2016). - The attacker can eavesdrop on the communication, steal sensitive data, or manipulate the exchanged information (Callegati et al., 2009). - Implementing strong encryption protocols (e.g., HTTPS) and proper certificate validation can help prevent MITM attacks.
Insider Threats	- Insider threats refer to malicious activities carried out by individuals with authorized access to cloud resources (Kandias et al., 2010). - Insiders, such as employees or contractors, may abuse their privileges to steal data, disrupt services, or cause damage (Salem et al., 2008). - Implementing strict access controls, monitoring user activities, and regularly auditing permissions can mitigate insider threats.
Misconfiguration and Inadequate Security Controls	- Misconfigurations in cloud settings, such as open ports, weak passwords, or misconfigured

	access controls, can expose cloud resources to attacks (Modi et al., 2013). - Attackers exploit these misconfigurations to gain unauthorized access, steal data, or compromise the cloud infrastructure (Fernandes et al., 2013).

These notable attacks highlight the potential consequences of the identified vulnerabilities, including data breaches, system compromise, and disruption of service. The exploitation of these vulnerabilities can have severe implications for SoftCorp, such as financial losses, reputational damage, and non-compliance with industry regulations.

Industry-based standards, such as the NIST Cloud Computing Security Reference Architecture (NIST SP 500-299) and the Cloud Security Alliance's Cloud Controls Matrix (CCM), provide guidelines and best practices for mitigating these attacks and ensuring cloud security (National Institute of Standards and Technology & National Institute of Standards and Technology, 2013). These standards offer a framework for implementing security controls, conducting risk assessments, and maintaining a secure cloud environment (*What Is the Cloud Controls Matrix (CCM)? | CSA*, 2020).

Recommendations for the Cloud Server

The evaluation of the cloud server's security revealed vulnerabilities that must be addressed before deployment. This section provides prioritized recommendations, based on industry tools and best practices, to fortify the cloud server's security posture for safe use in a DevOps environment.

1. **System Updates and Upgrades**

   The first step in securing the cloud server is to ensure that the operating system and installed packages are up to date with the latest security patches and updates. (Upgrades - Community Help Wiki, n.d).

   - Implement a regular system update and upgrade schedule.
   - Install unattended upgrades package, this will automatically install security updates and other critical updates, ensuring that systems remain secure and up to date without requiring manual intervention (Ubuntu Server Documentation | Ubuntu, n.d.).

2. **Apache Web Server Hardening**

   The scans revealed that the Apache web server version is outdated and vulnerable.

- Upgrade Apache to the latest stable version to mitigate known vulnerabilities.
- Harden the Apache configuration by disabling unnecessary modules, restricting access to sensitive files and directories, and configuring strong encryption settings.
- Install and configure the ModSecurity web application firewall for Apache to provide an additional layer of protection against web-based attacks.
- Disable the HTTP OPTIONS method if not required or restrict the information returned to minimize exposure of supported methods.

3. Security Headers Implementation

- To mitigate clickjacking and cross-site scripting (XSS) attacks, implement security headers such as X-Frame-Options and Content Security Policy (CSP).
- These headers instruct the browser to enforce strict security policies, preventing unauthorized framing and limiting the execution of potentially malicious scripts. Provide specific guidance on fixing CSP issues:
  - ✓ Remove wildcard directives and specify trusted sources explicitly.
  - ✓ Remove 'unsafe-eval' from script-src policy and refactor code to eliminate its need.
  - ✓ Remove 'unsafe-inline' from style-src policy and externalize inline styles.
  - ✓ Implement the X-Content-Type-Options response header with the "Nosniff" value to prevent MIME type confusion attacks in older browsers.

4. PHP Hardening

- Review and harden the PHP configuration to align with security best practices.
- Disable unnecessary PHP functions, limit file upload capabilities, and configure error handling to prevent information leakage.
- Regularly update PHP to the latest stable version and apply security patches promptly.
- Explicitly disable phpinfo() files in production environments to prevent information leakage (Remove hidden files and review application code to prevent exploitation by removing unnecessary timestamp disclosures or obfuscating them).

5. Directory Browsing and Indexing

- Disable directory browsing and indexing to prevent unauthorized access to sensitive files and directories.
- Ensure that proper access controls are in place and that files and directories are not inadvertently exposed to the public.
- Secure sensitive data directories like ownCloud/Nextcloud with appropriate access controls and permissions.

6. **jQuery Library Update**

   The scans identified the presence of outdated and vulnerable versions of the jQuery library.

   - Update jQuery to the latest stable release to mitigate potential security risks associated with known vulnerabilities.

7. **Encrypted Data Transmission**

   - Implement secure communication channels by enforcing the use of HTTPS for all sensitive data transmissions.
   - Configure strong encryption protocols such as TLS 1.2 or higher and obtain a valid SSL/TLS certificate from a trusted certificate authority, this prevents the ClearText Transmission as found in the greenbone scan result (Cleartext Transmission | GuardRails, 2023).

8. **Password Management**

- Enforce strong password policies, including minimum length, complexity requirements, and regular password expiration.
- Educate users on creating secure passwords and for enhanced security.

9. **SSH Hardening**

   - Harden the SSH configuration by disabling root login, using strong cryptographic algorithms, and limiting access to specific IP addresses or subnets.
   - Generate and use SSH key pairs for authentication instead of passwords to reduce the risk of brute-force attacks.

10. **Network Security**

    - Configure the firewall to restrict incoming and outgoing traffic to only necessary ports and services.
    - Implement fail2ban to protect against brute-force attacks and SSH intrusions.
    - Configure AppArmor or similar security modules to enforce granular access controls and limit the impact of potential security breaches.
    - Disable TCP timestamps if not required for network functionality to prevent potential information disclosure.
    - Block ICMP timestamp requests and disable ICMP timestamp responses if not needed to prevent revealing system clock state.

11. **Anti-CSRF Protection**

    - To fix the Cross-Site Request Forgery (CSRF) vulnerability, you should implement anti-CSRF tokens (also known as CSRF tokens or synchronizer tokens) in all forms that

perform sensitive actions, such as forms for authentication, updating user data, or performing transactions. Here's a concise step to implement anti-CSRF protection:

- Generate a unique, unpredictable token on the server-side for each user session or form submission. This token can be a cryptographically secure random value or a hash of the session ID combined with a secret key. Store this token in the user's session or as a hidden field in the form.

12. Server Header Information

- Minimize information disclosed in the Server HTTP response header or disable it if not required to reduce exposure of web server version details.
- This is done by setting *ServerTokens Prod ServerSignature Off* in the apache conf file.

Additional Recommendations for the Cloud Server

1. Secure Remote Access

- Implement a virtual private network (VPN) to secure remote access and encrypt network traffic.
- Enforce strong authentication and encryption mechanisms for VPN connections.

2. Installation of Anti-virus to help protect against malware and other malicious threats.

By implementing these security measures and adhering to industry best practices, the organization can significantly enhance the security posture of the target system, protect sensitive data, and mitigate the risk of cyber-attacks. Regular security assessments and ongoing monitoring should be performed to ensure the effectiveness of the implemented controls and to adapt to the evolving threat landscape.

DevOps Deployment Security Recommendations

As Softcorp transitions towards a DevOps environment, it is crucial to address security considerations beyond the scope of the cloud-based server. The following recommendations outline the necessary steps to secure the server and the surrounding infrastructure for a successful DevOps deployment.

1. Network Segmentation and DMZ

- Implement a segmented network architecture to isolate critical resources and minimize the impact of potential security breaches.
- Deploy a demilitarized zone (DMZ) to separate the internal network from the public-facing services.
- Place the cloud-based server in the DMZ and restrict direct access from the public internet to the internal network.
- Use firewalls, network access controls, and intrusion detection/prevention systems (IDS/IPS) to monitor and control traffic between network segments.

2. **Secrets Management**
    - Implement a secure secrets management solution to store and manage sensitive information, such as API keys, database credentials, and certificates.
    - Use tools like HashiCorp Vault, AWS Secrets Manager, or Azure Key Vault to securely store and rotate secrets.
    - Encrypt secrets at rest and in transit, and audit access to secrets to detect any unauthorized activities.
3. **Security Monitoring and Incident Response**
    - Establish a robust security monitoring and incident response plan to detect and respond to security incidents effectively.
    - Implement centralized logging and monitoring solutions to collect and analyze logs from various systems and applications.
    - Use security information and event management (SIEM) tools to correlate events and detect potential security threats.
    - Define clear incident response procedures, including roles and responsibilities, communication channels, and escalation paths**.**
4. **Continuous Integration and Continuous Deployment (CI/CD) Pipeline Security**
    - Secure the CI/CD pipeline to prevent unauthorized access and ensure the integrity of the deployment process.
    - Implement strong authentication and access controls for the CI/CD system, and limit permissions based on the principle of least privilege.
    - Use signed and verified container images to ensure the authenticity and integrity of the deployed artifacts.
    - Regularly monitor and audit the CI/CD pipeline for suspicious activities or anomalies.
5. **Infrastructure as Code (IaC)**
    - Adopt Infrastructure as Code (IaC) practices to manage and provision infrastructure resources consistently and securely. Use tools like Terraform, CloudFormation, or Ansible to define and manage infrastructure configurations.
    - Implement version control for IaC files to track changes, enable collaboration, and facilitate rollbacks if necessary.
    - Regularly review and audit IaC configurations to ensure compliance with security best practices.
6. **Serverless Security**

- If utilizing serverless architectures, such as AWS Lambda or Azure Functions, follow serverless security best practices.
- Implement least privilege access for serverless functions, and use secure coding practices to prevent common vulnerabilities like injection attacks or insecure dependencies.
- Monitor and log serverless function executions to detect and respond to security incidents promptly.

7. Security Awareness and Training

- Foster a culture of security awareness among all employees, including developers, operations teams, and management.
- Conduct regular security awareness training sessions to educate employees about common security risks, best practices, and their roles in maintaining a secure environment.
- Encourage employees to report suspicious activities or potential security incidents promptly.

8. Container Security

- If using containerization technologies like Docker or Kubernetes, ensure the security of the container ecosystem.
- Use trusted and verified container images from reputable sources.
- Regularly scan container images for vulnerabilities and update them to the latest secure versions.
- Implement container runtime security to monitor and enforce security policies on running containers.
- Use network policies to control communication between containers and limit the attack surface.

9. Secure Development Practices

- Implement secure coding practices and guidelines for all development teams.
- Conduct regular security training sessions to educate developers about common vulnerabilities, secure coding techniques, and best practices.
- Incorporate security testing, such as static code analysis and penetration testing, into the development pipeline to identify and remediate vulnerabilities early in the development lifecycle.

10. Compliance and Governance

- Ensure compliance with relevant industry standards and regulations, such as GDPR, HIPAA, or PCI DSS, depending on the nature of the business.
- Conduct regular security audits and assessments to validate the effectiveness of the implemented security controls.
- Establish governance processes to oversee and manage security risks, including regular risk assessments, policy reviews, and management reporting.

Softcorp can effectively secure their DevOps environment by implementing a holistic approach that includes secure development practices, infrastructure security, continuous monitoring, and a strong security culture.

Implementation of technical security recommendations

Following the security evaluation of SoftCorp's cloud server and the critical analysis of the identified vulnerabilities, a set of technical security recommendations were developed to address the identified risks and enhance the server's security posture. This section outlines the implementation of these recommendations, along with relevant code snippets and references to industry best practices and standards.

System Updates and Upgrades

Update and Upgrade

$ sudo apt update & Upgrade

The first step in securing the cloud server is to ensure that the operating system and installed packages are up to date with the latest security patches and updates.

```
admin@waecs:~$ sudo apt update
Hit:1 http://gb.archive.ubuntu.com/ubuntu jammy InRelease
Hit:2 http://gb.archive.ubuntu.com/ubuntu jammy-updates InRelease
Hit:3 http://gb.archive.ubuntu.com/ubuntu jammy-backports InRelease
Hit:4 http://gb.archive.ubuntu.com/ubuntu jammy-security InRelease
Hit:5 https://ppa.launchpadcontent.net/ondrej/apache2/ubuntu jammy InRelease
Hit:6 https://ppa.launchpadcontent.net/ondrej/php/ubuntu jammy InRelease
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
16 packages can be upgraded. Run 'apt list --upgradable' to see them.
admin@waecs:~$ sudo apt upgrade
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
Calculating upgrade... Done
The following packages were automatically installed and are no longer required:
  libapache2-mod-php8.1 php8.1 php8.1-cli php8.1-common php8.1-mysql php8.1-opcache php8.1-readline
  php8.2-common php8.2-zip
Use 'sudo apt autoremove' to remove them.
Get more security updates through Ubuntu Pro with 'esm-apps' enabled:
```

Automatic Updates (unattended Upgrades)

$ sudo apt-get install unattended-upgrades

This package is designed to automatically install security updates and other critical updates.

```
admin@waecs:~$ sudo apt-get install unattended-upgrades
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
unattended-upgrades is already the newest version (2.8ubuntu1).
0 upgraded, 0 newly installed, 0 to remove and 10 not upgraded.
admin@waecs:~$
```

$ /etc/apt/apt.conf.d/50unattended-upgrades ; "${distro_id}:${distro_codename}-updates";

The command above is used to configure the automatic update to run on the Ubuntu VM. The security update lines are uncommented by deleting the two slashes at the beginning of it.

```
  GNU nano 6.2                  /etc/apt/apt.conf.d/50unattended-upgrades *
// Automatically upgrade packages from these (origin:archive) pairs
//
// Note that in Ubuntu security updates may pull in new dependencies
// from non-security sources (e.g. chromium). By allowing the release
// pocket these get automatically pulled in.
Unattended-Upgrade::Allowed-Origins {
        "${distro_id}:${distro_codename}";
        "${distro_id}:${distro_codename}-security";
        // Extended Security Maintenance; doesn't necessarily exist for
        // every release and this system may not have it installed, but if
        // available, the policy for updates is such that unattended-upgrades
        // should also install from here by default.
        "${distro_id}ESMApps:${distro_codename}-apps-security";
        "${distro_id}ESM:${distro_codename}-infra-security";
        "${distro_id}:${distro_codename}-updates";
//      "${distro_id}:${distro_codename}-proposed";
//      "${distro_id}:${distro_codename}-backports";
};

// Python regular expressions, matching packages to exclude from upgrading
Unattended-Upgrade::Package-Blacklist {
    // The following matches all packages starting with linux-
//  "linux-";

    // Use $ to explicitely define the end of a package name. Without
    // the $, "libc6" would match all of them.
//  "libc6$";
//  "libc6-dev$";
//  "libc6-i686$";

    // Special characters need escaping
//  "libstdc\+\+6$";

                                    [ Read 143 lines ]
^G Help      ^O Write Out  ^W Where Is   ^K Cut       ^T Execute    ^C Location   M-U Undo
^X Exit      ^R Read File  ^\ Replace    ^U Paste     ^J Justify    ^/ Go To Line M-E Redo
```

Apache Web Server Hardening

Apache Version Upgrade

$ sudo add-apt-repository ppa:ondrej/apache2

This allows adding of a third-party software repository to an Ubuntu-based system in order to install newer versions of the Apache2 web server (*Apache Upgrade to 2.4.58 on Ubuntu 22.04*, n.d.).

```
admin@waecs: ~
File  Edit  View  Search  Terminal  Help
admin@waecs:~$ sudo add-apt-repository ppa:ondrej/apache2
[sudo] password for admin:
PPA publishes dbgsym, you may need to include 'main/debug' component
Repository: 'deb https://ppa.launchpadcontent.net/ondrej/apache2/ubuntu/ jammy main'
Description:
This branch follows latest Apache2 packages as maintained by the Debian Apache2 team with couple of compatibility patch
es on top.

It also includes some widely used Apache 2 modules (if you need some other feel free to send me a request).

IMPORTANT: The <foo>-backports is now required on older Ubuntu releases.

BUGS&FEATURES: This PPA now has a issue tracker: https://deb.sury.org/#bug-reporting

PLEASE READ: If you like my work and want to give me a little motivation, please consider donating: https://deb.sury.or
g/#donate
More info: https://launchpad.net/~ondrej/+archive/ubuntu/apache2
Adding repository.
Press [ENTER] to continue or Ctrl-c to cancel.
Adding deb entry to /etc/apt/sources.list.d/ondrej-ubuntu-apache2-jammy.list
Adding disabled deb-src entry to /etc/apt/sources.list.d/ondrej-ubuntu-apache2-jammy.list
Adding key to /etc/apt/trusted.gpg.d/ondrej-ubuntu-apache2.gpg with fingerprint 14AA40EC0831756756D7F66C4F4EA0AAE5267A6
C
Hit:1 http://gb.archive.ubuntu.com/ubuntu jammy InRelease
Hit:2 http://gb.archive.ubuntu.com/ubuntu jammy-updates InRelease
Hit:3 http://gb.archive.ubuntu.com/ubuntu jammy-backports InRelease
Hit:4 http://gb.archive.ubuntu.com/ubuntu jammy-security InRelease
Get:5 https://ppa.launchpadcontent.net/ondrej/apache2/ubuntu jammy InRelease [23.8 kB]
Hit:6 https://ppa.launchpadcontent.net/ondrej/php/ubuntu jammy InRelease
Get:7 https://ppa.launchpadcontent.net/ondrej/apache2/ubuntu jammy/main amd64 Packages [4,772 B]
Get:8 https://ppa.launchpadcontent.net/ondrej/apache2/ubuntu jammy/main Translation-en [3,364 B]
Fetched 32.0 kB in 1s (28.1 kB/s)
Reading package lists... Done
admin@waecs:~$
```

$ sudo apache2 -v

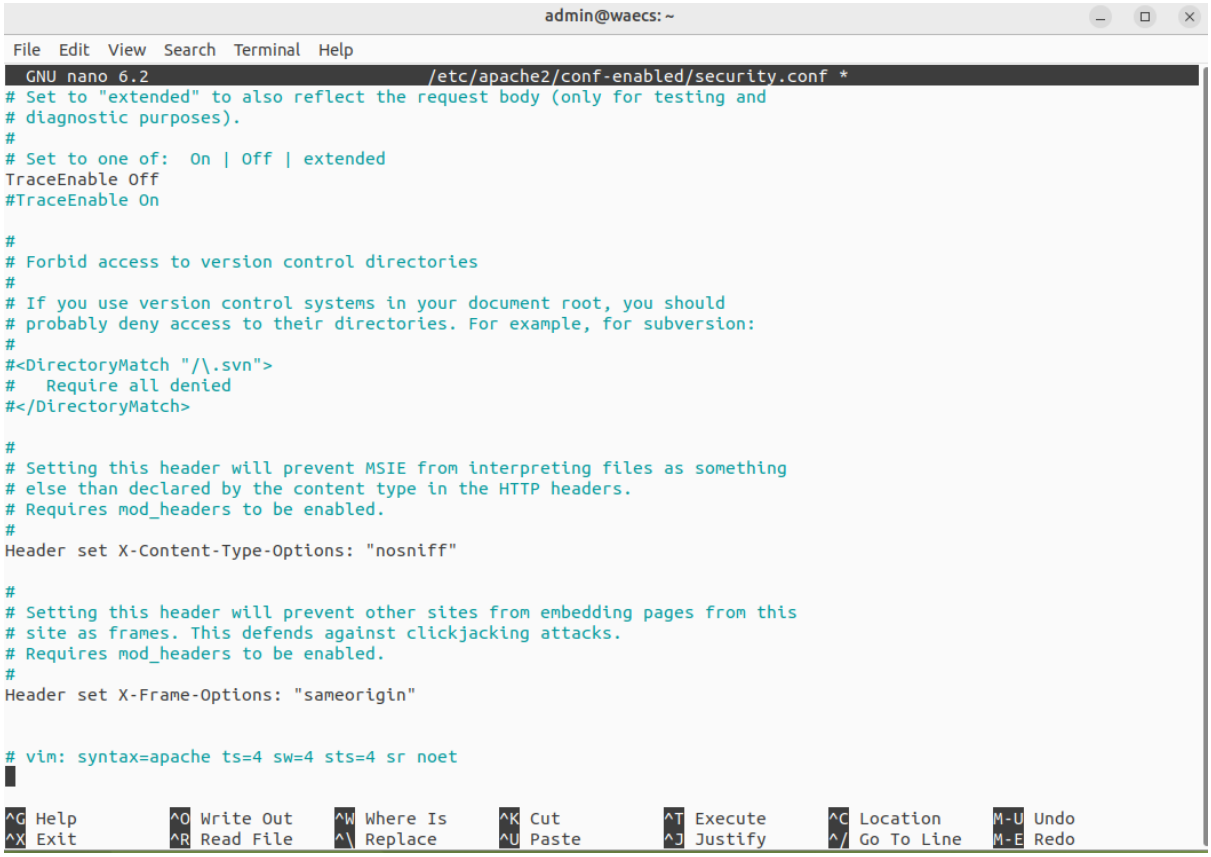
This shows the previous version of the apache2 web server has been updated.

```
admin@waecs:~$ sudo apache2 -v
Server version: Apache/2.4.59 (Ubuntu)
Server built:   2024-04-09T11:52:19
admin@waecs:~$
```

Apache Hardening

$ sudo nano /etc/apache2/conf-enabled/security.conf

After changing the ServerTokens to “Prod” and uncommenting Header X-content and X-Frame, this will improve the security of the of the web application (Krishnamurthy et al., 2008).



$ sudo nano /etc/apache2/conf-enabled/security.conf

A custom file has been created and edited in the apache2 config file. This is done to hide sensitive information and header inside the apache2 installation.

```
admin@waecs: ~
File  Edit  View  Search  Terminal  Help
  GNU nano 6.2                    /etc/apache2/conf-available/custom.conf *
ServerTokens Prod
ServerSignature Off
TraceEnable Off
Options all -Indexes
Header unset ETag
Header always unset X-Powered-By
FileETag None

^G Help      ^O Write Out   ^W Where Is   ^K Cut       ^T Execute   ^C Location   M-U Undo
^X Exit      ^R Read File   ^\ Replace    ^U Paste     ^J Justify   ^/ Go To Line  M-E Redo
```

ModSecurity Installation

$ sudo apt install libapache2-mod-security2

The command above is used to install Modsecurity. ModSecurity is an open-source web application firewall that provides real-time monitoring, logging, and security for web applications. It is a highly configurable tool that can be integrated with various web servers like Apache to protect against common web application vulnerabilities (*OWASP ModSecurity | OWASP Foundation*, 2024).

```
admin@waecs: /usr/bin
File  Edit  View  Search  Terminal  Help
admin@waecs:/usr/bin$ sudo apt install libapache2-mod-security2
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
libapache2-mod-security2 is already the newest version (2.9.5-1).
0 upgraded, 0 newly installed, 0 to remove and 0 not upgraded.
admin@waecs:/usr/bin$ sudo systemctl restart apache2
admin@waecs:/usr/bin$ apt-cache show libapache2-mod-security2
Package: libapache2-mod-security2
Architecture: amd64
Version: 2.9.5-1
Priority: optional
Section: universe/httpd
Source: modsecurity-apache
Origin: Ubuntu
Maintainer: Ubuntu Developers <ubuntu-devel-discuss@lists.ubuntu.com>
Original-Maintainer: Alberto Gonzalez Iniesta <agi@inittab.org>
Bugs: https://bugs.launchpad.net/ubuntu/+filebug
Installed-Size: 1089
Depends: libxml2 (>= 2.9.0), libapr1 (>= 1.2.7), libaprutil1 (>= 1.4.0), libc6 (>= 2.34), libcurl3-gnu
tls (>= 7.16.2), liblua5.1-0, libpcre3, libyajl2 (>= 2.0.4), apache2-api-20120211, apache2-bin (>= 2.4
.16)
Recommends: modsecurity-crs
Filename: pool/universe/m/modsecurity-apache/libapache2-mod-security2_2.9.5-1_amd64.deb
Size: 265178
MD5sum: b466eff62d6580d93cfaacb6c6972e01
```

The a2enmod headers are enabled below.

```
admin@waecs:/$ sudo   systemctl restart apache2
admin@waecs:/$ sudo a2enmod headers
Module headers already enabled
admin@waecs:/$
```

$ sudo nano /etc/modsecurity/modsecurity.conf.

In the Modsecurity config file, the SecRuleEngine is set to “ON” which enables the core ModSecurity engine.

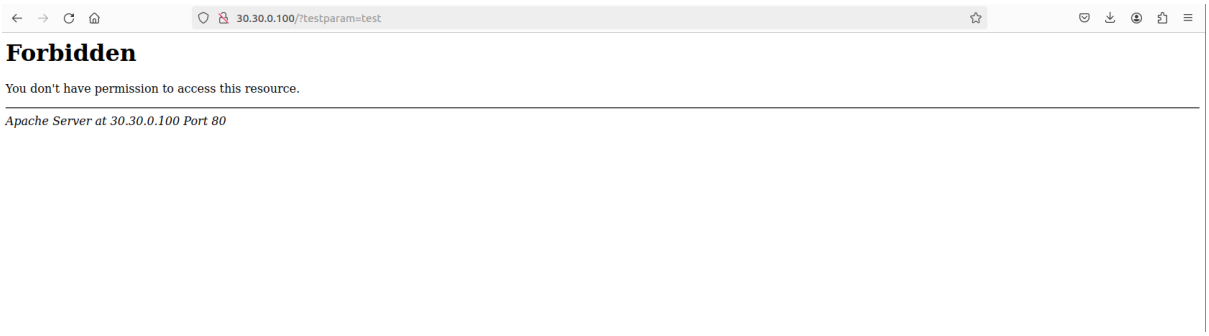
```
admin@waecs: /
File  Edit  View  Search  Terminal  Help
  GNU nano 6.2                    /etc/modsecurity/modsecurity.conf *
# only to start with, because that minimises the chances of post-installation
# disruption.
#
SecRuleEngine On


# -- Request body handling --------------------------------------------------

# Allow ModSecurity to access request bodies. If you don't, ModSecurity
# won't be able to see any POST parameters, which opens a large security
# hole for attackers to exploit.
#
SecRequestBodyAccess On


# Enable XML request body parser.
# Initiate XML Processor in case of xml content-type
#
SecRule REQUEST_HEADERS:Content-Type "(?:application(?:/soap\+|/)|text/)xml" \
     "id:'200000',phase:1,t:none,t:lowercase,pass,nolog,ctl:requestBodyProcessor=XML"

# Enable JSON request body parser.

^G Help      ^O Write Out   ^W Where Is   ^K Cut       ^T Execute    ^C Location   M-U Undo
^X Exit      ^R Read File   ^\ Replace    ^U Paste     ^J Justify    ^/ Go To Line M-E Redo
```

$ sudo nano /etc/apache2/sites-available/000-default.conf

The SecRuleEngine also set to “ON” in the default apache2 config file, and SecRule ARGS:testparam "@contains test" "id:999,deny,status:403,msg:'Test Successful'" directive is a ModSecurity rule that denies access if the testparam argument contains the word "test".

```
admin@waecs: ~
File  Edit  View  Search  Terminal  Help
  GNU nano 6.2          /etc/apache2/sites-available/000-default.conf
        ErrorLog ${APACHE_LOG_DIR}/error.log
        CustomLog ${APACHE_LOG_DIR}/access.log combined

        # For most configuration files from conf-available/, which are
        # enabled or disabled at a global level, it is possible to
        # include a line for only one particular virtual host. For example the
        # following line enables the CGI configuration for this host only
        # after it has been globally disabled with "a2disconf".
        #Include conf-available/serve-cgi-bin.conf


        RewriteEngine On
        RewriteCond %{REQUEST_METHOD} ^(HEAD|PUT|DELETE|PATCH|TRACK|OPTIONS)
        RewriteRule .* - [F]

        SecRuleEngine On
        SecRule ARGS:testparam "@contains test" "id:999,deny,status:403,msg:'Test Successf>


</VirtualHost>

^G Help      ^O Write Out  ^W Where Is   ^K Cut       ^T Execute    ^C Location
^X Exit      ^R Read File  ^\ Replace    ^U Paste     ^J Justify    ^/ Go To Line
```

The image below showcases the ModSecurity web application firewall's efficient detection and blocking of malicious requests, a crucial part of the Apache web server's security and access control measures.



Disabling HTTP OPTIONS

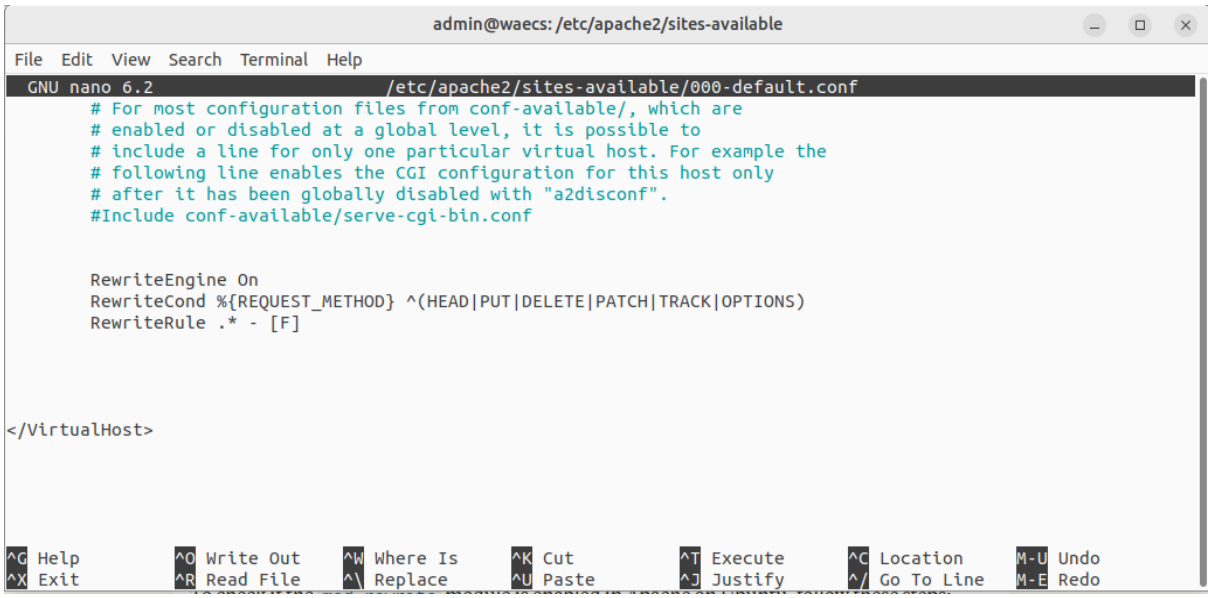
$ sudo nano /etc/apache2/sites-available/000-default.conf

RewriteEngine On

RewriteCond %{REQUEST_METHOD} ^(TRACE|TRACK|OPTIONS) RewriteRule .* - [F]

The above line of command is edited into the 000-default.conf file. This causes the HTTP

OPTIONS to be disabled for best security practice (Rahul & Rahul, 2024).



Security Headers Implementation

$ sudo nano /etc/apache2/apache2.conf

X-Content-Type-Options: nosniff and X-Frame-Options: SAMEORIGIN has already been implemented in the Apache web server hardening.

We only need to implement the following.

- Remove wildcard directives and specify trusted sources explicitly.
- Remove 'unsafe-eval' from script-src policy and refactor code to eliminate its need.
- Remove 'unsafe-inline' from style-src policy and externalize inline styles.

```
admin@waecs: ~
File  Edit  View  Search  Terminal  Help
  GNU nano 6.2                                  /etc/apache2/apache2.conf
# requests.
#
# Note that the use of %{X-Forwarded-For}i instead of %h is not recommended.
# Use mod_remoteip instead.
#
LogFormat "%v:%p %h %l %u %t \"%r\" %>s %O \"%{Referer}i\" \"%{User-Agent}i\"" vhost_combined
LogFormat "%h %l %u %t \"%r\" %>s %O \"%{Referer}i\" \"%{User-Agent}i\"" combined
LogFormat "%h %l %u %t \"%r\" %>s %O" common
LogFormat "%{Referer}i -> %U" referer
LogFormat "%{User-agent}i" agent

# Include of directories ignores editors' and dpkg's backup files,
# see README.Debian for details.

# Include generic snippets of statements
IncludeOptional conf-enabled/*.conf

# Include the virtual host configurations:
IncludeOptional sites-enabled/*.conf



<IfModule mod_headers.c>
Header always set Content-Security-Policy "default-src 'self';script-src 'self';style-src 'self';img-src 'self';form-action >

</IfModule>

^G Help      ^O Write Out  ^W Where Is   ^K Cut       ^T Execute    ^C Location   M-U Undo      M-A Set Mark
^X Exit      ^R Read File  ^\ Replace    ^U Paste     ^J Justify    ^/ Go To Line M-E Redo      M-6 Copy
```

PHP Hardening

$ sudo nano /etc/php/8.1/cli/php.ini

The following changes are going to done in the php conf file.

expose_php = Off

display_errors = Off

mail.add_x_header = Off

disable_functions =

show_source,system,shell_exec,passthru,exec,phpinfo,popen,proc_open,all

ow_url_fopen,curl_exec,curl_multi_exec

file_uploads = Off

The changes made to the PHP configuration file are focused on hardening the PHP environment to enhance security (Inc, 2022).

```
admin@waecs: ~
File  Edit  View  Search  Terminal  Help
  GNU nano 6.2                    /etc/php/8.1/cli/php.ini *

;;;;;;;;;;;;;;;;;;
; Miscellaneous ;
;;;;;;;;;;;;;;;;;;

; Decides whether PHP may expose the fact that it is installed on the server
; (e.g. by adding its signature to the Web server header).  It is no security
; threat in any way, but it makes it possible to determine whether you use PHP
; on your server or not.
; https://php.net/expose-php
expose_php = Off

;;;;;;;;;;;;;;;;;;;;
; Resource Limits ;
;;;;;;;;;;;;;;;;;;;;

; Maximum execution time of each script, in seconds
; https://php.net/max-execution-time
; Note: This directive is hardcoded to 0 for the CLI SAPI
max_execution_time = 30

^G Help      ^O Write Out ^W Where Is  ^K Cut       ^T Execute   ^C Location
^X Exit      ^R Read File ^\ Replace   ^U Paste     ^J Justify   ^/ Go To Line
```

```
admin@waecs: ~
File  Edit  View  Search  Terminal  Help
  GNU nano 6.2                    /etc/php/8.1/cli/php.ini *
; open_basedir, if set, limits all file operations to the defined directory
; and below.  This directive makes most sense if used in a per-directory
; or per-virtualhost web server configuration file.
; Note: disables the realpath cache
; https://php.net/open-basedir
;open_basedir =

; This directive allows you to disable certain functions.
; It receives a comma-delimited list of function names.
; https://php.net/disable-functions
disable_functions = show_source,system,shell_exec,passthru,exec,phpinfo,popen,proc_open,allow_url_fopen,curl_exec,c>

; This directive allows you to disable certain classes.
; It receives a comma-delimited list of class names.
; https://php.net/disable-classes
disable_classes =

; Colors for Syntax Highlighting mode.  Anything that's acceptable in
; <span style="color: ???????"> would work.
; https://php.net/syntax-highlighting
;highlight.string  = #DD0000
;highlight.comment = #FF9900
;highlight.keyword = #007700
;highlight.default = #0000BB

^G Help      ^O Write Out ^W Where Is  ^K Cut       ^T Execute   ^C Location   M-U Undo
^X Exit      ^R Read File ^\ Replace   ^U Paste     ^J Justify   ^/ Go To Line  M-E Redo
```

Directory browsing and Indexing.

$ sudo nano /etc/apache2/apache2.conf

'Indexes' has been added to the <Directory /> block shown in the image below, this will block and disable the directory indexing.

```
admin@waecs: ~
File  Edit  View  Search  Terminal  Help
  GNU nano 6.2                    /etc/apache2/apache2.conf
# The former is used by web applications packaged in Debian,
# the latter may be used for local directories served by the web server. If
# your system is serving content from a sub-directory in /srv you must allow
# access here, or in any related virtual host.
<Directory />
        Options Indexes FollowSymLinks
        AllowOverride None
        Require all denied
</Directory>

<Directory /usr/share>
        AllowOverride None
        Require all granted
</Directory>

<Directory /var/www/>
        Options Indexes FollowSymLinks
        AllowOverride None
        Require all granted
</Directory>

#<Directory /srv/>
#       Options Indexes FollowSymLinks
#       AllowOverride None
#       Require all granted
#</Directory>

^G Help      ^O Write Out   ^W Where Is    ^K Cut       ^T Execute   ^C Location
^X Exit      ^R Read File   ^\ Replace     ^U Paste     ^J Justify   ^/ Go To Line
```

jQuery Library Update

$ sudo wget https://code.jquery.com/jquery-3.6.0.min.js

This command uses the wget utility to download the minified jQuery 3.6.0 JavaScript file from the specified URL and save it in the /var/www/html directory (Wodarek, 2022).

```
admin@waecs: /var/www/html
File  Edit  View  Search  Terminal  Help
admin@waecs:/var/www/html$ sudo wget https://code.jquery.com/jquery-3.6.0.min.js
--2024-05-14 18:43:46--  https://code.jquery.com/jquery-3.6.0.min.js
Resolving code.jquery.com (code.jquery.com)... 151.101.130.137, 151.101.194.137,
 151.101.2.137, ...
Connecting to code.jquery.com (code.jquery.com)|151.101.130.137|:443... connecte
d.
HTTP request sent, awaiting response... 200 OK
Length: 89501 (87K) [application/javascript]
Saving to: ‘jquery-3.6.0.min.js’

jquery-3.6.0.min.js 100%[===================>]  87.40K  --.-KB/s    in 0.008s

2024-05-14 18:43:46 (10.5 MB/s) - ‘jquery-3.6.0.min.js’ saved [89501/89501]

admin@waecs:/var/www/html$
```

The old jquery.min.js file has been replaced by the new and updated jquery-3.6.0.min.js file in the /var/www.html directory as shown below.

```
admin@waecs: /var/www/html/js
File  Edit  View  Search  Terminal  Help

*** System restart required ***
Last login: Tue May 14 18:24:01 2024 from 30.30.0.40
admin@waecs:~$ cd /var/www/html
admin@waecs:/var/www/html$ ls
css                 fonts       images      js          phpinfo.php
development.html    forum.html  index.html  owncloud    register.html
admin@waecs:/var/www/html$ cd js
admin@waecs:/var/www/html/js$ ls
app.js                      jquery.easing.min.js   owl.carousel.min.js
bootstrap.min.js            jquery.min.js          SmoothScroll.js
classie.js                  jquery.nav.js          switcher.js
jquery-3.6.0.min.js         jquery.stellar.min.js  waypoints.min.js
jquery.counterup.min.js     modalEffects.js
admin@waecs:/var/www/html/js$ sudo rm jquery.min.js
[sudo] password for admin:
admin@waecs:/var/www/html/js$ ls
app.js                      jquery.easing.min.js   SmoothScroll.js
bootstrap.min.js            jquery.nav.js          switcher.js
classie.js                  jquery.stellar.min.js  waypoints.min.js
jquery-3.6.0.min.js         modalEffects.js
jquery.counterup.min.js     owl.carousel.min.js
admin@waecs:/var/www/html/js$
```

Encrypted Data Transmission

$ sudo apt install certbot python3-certbot-apache

After running this command, Certbot will be installed on the system, and the Apache plugin will be available to simplify the process of obtaining and managing SSL/TLS certificates for websites hosted on the Apache web server.

```
admin@waecs: ~
File  Edit  View  Search  Terminal  Help
admin@waecs:~$ sudo apt install certbot python3-certbot-apache
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following additional packages will be installed:
  augeas-lenses libaugeas0 python3-acme python3-augeas python3-certbot python3-configargparse
  python3-icu python3-josepy python3-parsedatetime python3-requests-toolbelt python3-rfc3339
  python3-zope.component python3-zope.event python3-zope.hookable
Suggested packages:
  augeas-doc python-certbot-doc python3-certbot-nginx augeas-tools python-acme-doc
  python-certbot-apache-doc
The following NEW packages will be installed:
  augeas-lenses certbot libaugeas0 python3-acme python3-augeas python3-certbot
  python3-certbot-apache python3-configargparse python3-icu python3-josepy
  python3-parsedatetime python3-requests-toolbelt python3-rfc3339 python3-zope.component
  python3-zope.event python3-zope.hookable
0 upgraded, 16 newly installed, 0 to remove and 17 not upgraded.
Need to get 1,552 kB of archives.
After this operation, 7,681 kB of additional disk space will be used.
Do you want to continue? [Y/n]
Get:1 http://gb.archive.ubuntu.com/ubuntu jammy/universe amd64 augeas-lenses all 1.13.0-1 [321 kB
]
Get:2 http://gb.archive.ubuntu.com/ubuntu jammy/universe amd64 libaugeas0 amd64 1.13.0-1 [200 kB]
Get:3 http://gb.archive.ubuntu.com/ubuntu jammy/universe amd64 python3-josepy all 1.10.0-1 [22.0
kB]
Get:4 http://gb.archive.ubuntu.com/ubuntu jammy/main amd64 python3-requests-toolbelt all 0.9.1-1
[38.0 kB]
Get:5 http://gb.archive.ubuntu.com/ubuntu jammy/main amd64 python3-rfc3339 all 1.1-3 [7,110 B]
Get:6 http://gb.archive.ubuntu.com/ubuntu jammy-updates/universe amd64 python3-acme all 1.21.0-1u
buntu0.1 [36.4 kB]
Get:7 http://gb.archive.ubuntu.com/ubuntu jammy/universe amd64 python3-augeas all 0.5.0-1.1 [9,12
4 B]
Get:8 http://gb.archive.ubuntu.com/ubuntu jammy/universe amd64 python3-configargparse all 1.5.3-1
```

$ sudo certbot –apache

This command is used to run Certbot to obtain and install the SSL/TLS certificate.

```
admin@waecs: ~
File  Edit  View  Search  Terminal  Help
admin@waecs:~$ sudo certbot --apache
Saving debug log to /var/log/letsencrypt/letsencrypt.log
Enter email address (used for urgent renewal and security notices)
 (Enter 'c' to cancel): emmanuelateji@gmail.com

- - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - -
Please read the Terms of Service at
https://letsencrypt.org/documents/LE-SA-v1.4-April-3-2024.pdf. You must agree in
order to register with the ACME server. Do you agree?
- - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - -
(Y)es/(N)o: yes

- - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - -
Would you be willing, once your first certificate is successfully issued, to
share your email address with the Electronic Frontier Foundation, a founding
partner of the Let's Encrypt project and the non-profit organization that
develops Certbot? We'd like to send you email about our work encrypting the web,
EFF news, campaigns, and ways to support digital freedom.
- - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - - -
(Y)es/(N)o: yes
Account registered.
Please enter the domain name(s) you would like on your certificate (comma and/or
```

$ sudo nano /etc/apache2/sites-available/default-ssl.conf

The default-ssl.conf file is configured with the lines below to enforce HTTPS, so you can configure the web server to redirect all HTTP requests to HTTPS.

RewriteEngine On

RewriteCond %{HTTPS} off

RewriteRule ^(.*)$ https://%{HTTP_HOST}%{REQUEST_URI} [L,R=301]

```
admin@waecs: /etc/apache2/sites-available
File  Edit  View  Search  Terminal  Help
  GNU nano 6.2                          default-ssl.conf
                #        the SSL/TLS standard but is needed for some brain-dead browsers. Use
                #        this when you receive I/O errors because of the standard approach where
                #        mod_ssl sends the close notify alert.
                #   o ssl-accurate-shutdown:
                #        This forces an accurate shutdown when the connection is closed, i.e. a
                #        SSL close notify alert is send and mod_ssl waits for the close notify
                #        alert of the client. This is 100% SSL/TLS standard compliant, but in
                #        practice often causes hanging connections with brain-dead browsers. Use
                #        this only for browsers where you know that their SSL implementation
                #        works correctly.
                #   Notice: Most problems of broken clients are also related to the HTTP
                #   keep-alive facility, so you usually additionally want to disable
                #   keep-alive for those clients, too. Use variable "nokeepalive" for this.
                #   Similarly, one has to force some clients to use HTTP/1.0 to workaround
                #   their broken HTTP/1.1 implementation. Use variables "downgrade-1.0" and
                #   "force-response-1.0" for this.
                # BrowserMatch "MSIE [2-6]" \
                #               nokeepalive ssl-unclean-shutdown \
                #               downgrade-1.0 force-response-1.0

        </VirtualHost>
                RewriteEngine On
                RewriteCond %{HTTPS} off
                RewriteRule ^(.*)$ https://%{HTTP_HOST}%{REQUEST_URI} [L,R=301]

</IfModule>

# vim: syntax=apache ts=4 sw=4 sts=4 sr noet

^G Help      ^O Write Out   ^W Where Is    ^K Cut       ^T Execute     ^C Location
^X Exit      ^R Read File   ^\ Replace     ^U Paste     ^J Justify     ^/ Go To Line
```

Password Management

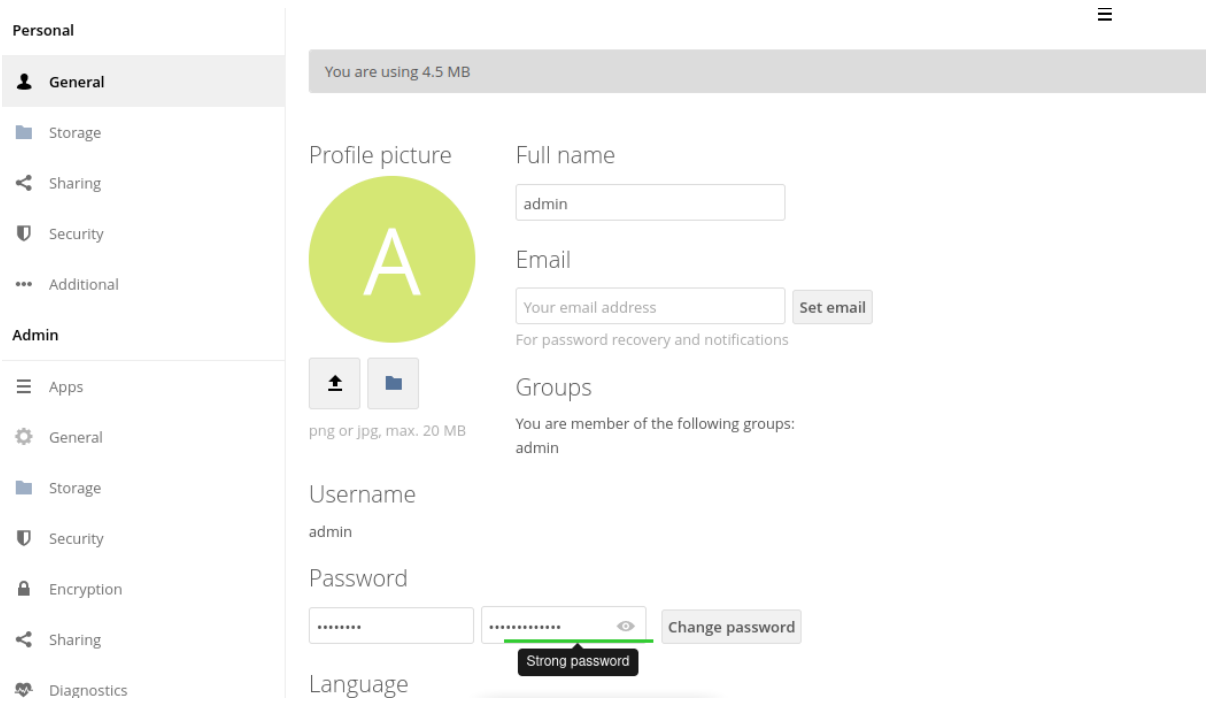
Admin password change

$ sudo passwd admin

The command is used to change the password for the 'admin' user account on the system. It's important to use a strong, secure password to protect the administrative access to the system.

```
admin@waecs: ~
File  Edit  View  Search  Terminal  Help
admin@waecs:~$ sudo passwd admin
New password:
Retype new password:
passwd: password updated successfully
admin@waecs:~$
```

Additionally, the owncloud web server at 30.30.0.100/owncloud/index.php password has been changed to a new, strong, and secure password.



SSH Hardening.

Disabling Weak MAC Algorithms

$ sudo nano /etc/ssh/sshd_config/

The sshd_condog file is configured by add this lines of algorithm:

MACs hmac-sha2-512-etm@openssh.com,hmac-sha2-256-etm@openssh.com,hmac-ripemd160-etm@openssh.com,umac-128-etm@openssh.com,hmac-sha2-512,hmac-sha2-256,hmac-ripemd160,umac-128@openssh.com.

These algorithms are used to ensure the integrity and authenticity of the SSH session. The "etm" algorithms use Encrypt-then-MAC, which is considered a more secure approach compared to the non-etm versions (Hardening SSH MAC Algorithms - Red Hat Customer Portal, 2019).

```
admin@waecs: /etc/apache2/sites-available
File  Edit  View  Search  Terminal  Help
  GNU nano 6.2                          /etc/ssh/sshd_config

# no default banner path
#Banner none

# Allow client to pass locale environment variables
AcceptEnv LANG LC_*

# override default of no subsystems
Subsystem       sftp    /usr/lib/openssh/sftp-server

# Example of overriding settings on a per-user basis
#Match User anoncvs
#       X11Forwarding no
#       AllowTcpForwarding no
#       PermitTTY no
#       ForceCommand cvs server


MACs hmac-sha2-512-etm@openssh.com,hmac-sha2-256-etm@openssh.com,hmac-sha2-512,hmac-sha2-256

^G Help      ^O Write Out   ^W Where Is   ^K Cut       ^T Execute   ^C Location   M-U Undo
^X Exit      ^R Read File   ^\ Replace    ^U Paste     ^J Justify   ^/ Go To Line M-E Redo
```

Creating SSH Key Pairs

$ ssh-keygen

The command is used to generate SSH keys, which are cryptographic keys used for secure authentication and encryption in SSH connections.

This provides a more secure alternative to password-based authentication and helps prevent unauthorized access to your systems.

```
admin@waecs: ~
File  Edit  View  Search  Terminal  Help
admin@waecs:~$ ssh-keygen
Generating public/private rsa key pair.
Enter file in which to save the key (/home/admin/.ssh/id_rsa):
Created directory '/home/admin/.ssh'.
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/admin/.ssh/id_rsa
Your public key has been saved in /home/admin/.ssh/id_rsa.pub
The key fingerprint is:
SHA256:TzByv33sFq3LKH11eoTL7yC68P+OrlB+YUAtuu14+ds admin@waecs
The key's randomart image is:
+---[RSA 3072]----+
|          ..     |
|         .. .    |
|       . +...    |
|        o.+ .    |
|         So+ o  o |
|         .=.+ oo =|
|         oo+o+.+B.|
|         .+=o.OB..|
|          .=BB*E=o|
+----[SHA256]-----+
admin@waecs:~$
```

Network Security

Firewall Configuration

$ sudo ufw allow ssh, http, https, and “Apache”.

The command above shows that the firewall (ufw) has been configured to allow SSH, HTTP, and HTTPS traffic from any IP address permitting remote access and web-based access to the system, while blocking other incoming traffic.

```
admin@waecs:~$ sudo ufw allow ssh
Rules updated
Rules updated (v6)
admin@waecs:~$ sudo ufw allow http
Rules updated
Rules updated (v6)
admin@waecs:~$ sudo ufw allow https
Rules updated
Rules updated (v6)
admin@waecs:~$ sudo ufw enable
Firewall is active and enabled on system startup
admin@waecs:~$ sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To                         Action      From
--                         ------      ----
22/tcp                     ALLOW IN    Anywhere
80/tcp                     ALLOW IN    Anywhere
443                        ALLOW IN    Anywhere
22/tcp (v6)                ALLOW IN    Anywhere (v6)
80/tcp (v6)                ALLOW IN    Anywhere (v6)
443 (v6)                   ALLOW IN    Anywhere (v6)

admin@waecs:~$ _
```

These commands also blocks ICMP timestamp requests discovered during Nessus scan.

```
admin@waecs:/etc/apache2/sites-available$ sudo ufw allow in "Apache"
Rule added
Rule added (v6)
admin@waecs:/etc/apache2/sites-available$ sudo ufw allow in "Apache"
Skipping adding existing rule
Skipping adding existing rule (v6)
admin@waecs:/etc/apache2/sites-available$ sudo ufw status
Status: active

To                         Action      From
--                         ------      ----
22/tcp                     ALLOW       Anywhere
80/tcp                     ALLOW       Anywhere
443                        ALLOW       Anywhere
Apache                     ALLOW       Anywhere
22/tcp (v6)                ALLOW       Anywhere (v6)
80/tcp (v6)                ALLOW       Anywhere (v6)
443 (v6)                   ALLOW       Anywhere (v6)
Apache (v6)                ALLOW       Anywhere (v6)
```

Fail2ban Installation

$ sudo apt install fail2ban

The fail2ban package is installed. It is a security tool used to prevent brute-force attacks by monitoring system logs and blocking suspicious IP addresses.

```
admin@waecs: ~
File  Edit  View  Search  Terminal  Help
admin@waecs:~$ sudo apt install fail2ban
[sudo] password for admin:
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following packages were automatically installed and are no longer required:
  libapache2-mod-php8.1 php8.1 php8.1-cli php8.1-common php8.1-mysql
  php8.1-opcache php8.1-readline php8.2-common php8.2-zip
Use 'sudo apt autoremove' to remove them.
The following additional packages will be installed:
  python3-pyinotify whois
Suggested packages:
  mailx monit sqlite3 python-pyinotify-doc
The following NEW packages will be installed:
  fail2ban python3-pyinotify whois
0 upgraded, 3 newly installed, 0 to remove and 10 not upgraded.
Need to get 473 kB of archives.
After this operation, 2,486 kB of additional disk space will be used.
Do you want to continue? [Y/n]
```

$ sudo systemctl status fail2ban

This command output demonstrates starting up the fail2ban service on a Linux Ubuntu machine and verifying that it is running correctly.

```
admin@waecs: ~
File  Edit  View  Search  Terminal  Help
admin@waecs:~$ sudo systemctl start fail2ban
admin@waecs:~$ sudo systemctl status fail2ban
● fail2ban.service - Fail2Ban Service
     Loaded: loaded (/lib/systemd/system/fail2ban.service; disabled; vendor pre>
     Active: active (running) since Wed 2024-05-15 18:03:16 UTC; 28s ago
       Docs: man:fail2ban(1)
   Main PID: 9211 (fail2ban-server)
      Tasks: 5 (limit: 2220)
     Memory: 13.1M
        CPU: 140ms
     CGroup: /system.slice/fail2ban.service
             └─9211 /usr/bin/python3 /usr/bin/fail2ban-server -xf start

May 15 18:03:16 waecs systemd[1]: Started Fail2Ban Service.
May 15 18:03:16 waecs fail2ban-server[9211]: Server ready
lines 1-13/13 (END)
```

AppArmor configuration

$ sudo apt install apparmor-utils

The apparmor-utils package on Linux is installed using apt, providing user-space tools for managing AppArmor profiles, a security module that restricts program capabilities.

```
admin@waecs:~$ sudo apt install apparmor-utils
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following packages were automatically installed and are no longer required:
  libapache2-mod-php8.1 php8.1 php8.1-cli php8.1-common php8.1-mysql
  php8.1-opcache php8.1-readline php8.2-common php8.2-zip
Use 'sudo apt autoremove' to remove them.
The following additional packages will be installed:
  python3-apparmor python3-libapparmor
Suggested packages:
  vim-addon-manager
The following NEW packages will be installed:
  apparmor-utils python3-apparmor python3-libapparmor
0 upgraded, 3 newly installed, 0 to remove and 0 not upgraded.
Need to get 170 kB of archives.
After this operation, 1,186 kB of additional disk space will be used.
Do you want to continue? [Y/n]
```

$ sudo aa-genprof /usr/bin/dig

The command output shows the steps involved in updating and generating an AppArmor profile for the "dig" command, which is a tool used for DNS lookups.

```
admin@waecs: /usr/bin
File  Edit  View  Search  Terminal  Help
dig
admin@waecs:/usr/bin$ sudo aa-genprof /usr/bin/dig
Updating AppArmor profiles in /etc/apparmor.d.
Writing updated profile for /usr/bin/dig.
Setting /usr/bin/dig to complain mode.

Before you begin, you may wish to check if a
profile already exists for the application you
wish to confine. See the following wiki page for
more information:
https://gitlab.com/apparmor/apparmor/wikis/Profiles

Profiling: /usr/bin/dig

Please start the application to be profiled in
another window and exercise its functionality now.

Once completed, select the "Scan" option below in
order to scan the system logs for AppArmor events.

For each AppArmor event, you will be given the
opportunity to choose whether the access should be
allowed or denied.

[(S)can system log for AppArmor events] / (F)inish
```

$ sudo aa-status

The output of the command provides a summary of the current AppArmor security policies, outlining the profiles of applications and system components and their operating mode.

```
admin@waecs:/usr/bin$ sudo aa-status
apparmor module is loaded.
18 profiles are loaded.
18 profiles are in enforce mode.
   /usr/bin/dig
   /usr/bin/man
   /usr/lib/NetworkManager/nm-dhcp-client.action
   /usr/lib/NetworkManager/nm-dhcp-helper
   /usr/lib/connman/scripts/dhclient-script
   /usr/lib/cups/backend/cups-pdf
   /usr/sbin/cups-browsed
   /usr/sbin/cupsd
   /usr/sbin/cupsd//third_party
   /usr/sbin/mysqld
   /{,usr/}sbin/dhclient
   lsb_release
   man_filter
   man_groff
   nvidia_modprobe
   nvidia_modprobe//kmod
   tcpdump
   ubuntu_pro_apt_news
0 profiles are in complain mode.
0 profiles are in kill mode.
0 profiles are in unconfined mode.
3 processes have profiles defined.
```

$ sudo systemctl status apparmor

The AppArmor service is loaded and active, with various processes and profiles displayed, including enforcement, complain, and unconfined processes with defined profiles.

```
admin@waecs: /usr/bin
File  Edit  View  Search  Terminal  Help
3 processes have profiles defined.
0 processes are in enforce mode.
0 processes are in complain mode.
3 processes are unconfined but have a profile defined.
   /usr/sbin/cups-browsed (874)
   /usr/sbin/cupsd (803)
   /usr/sbin/mysqld (899)
0 processes are in mixed mode.
0 processes are in kill mode.
admin@waecs:/usr/bin$ sudo systemctl status apparmor
● apparmor.service - Load AppArmor profiles
     Loaded: loaded (/lib/systemd/system/apparmor.service; enabled; vendor preset: enabled)
     Active: active (exited) since Thu 2024-05-16 18:02:24 UTC; 12min ago
       Docs: man:apparmor(7)
             https://gitlab.com/apparmor/apparmor/wikis/home/
    Process: 1519 ExecStart=/lib/apparmor/apparmor.systemd reload (code=exited, status=0/SUCCESS)
   Main PID: 1519 (code=exited, status=0/SUCCESS)
        CPU: 45ms

May 16 18:02:24 waecs systemd[1]: Starting Load AppArmor profiles...
May 16 18:02:24 waecs apparmor.systemd[1519]: Restarting AppArmor
May 16 18:02:24 waecs apparmor.systemd[1519]: Reloading AppArmor profiles
May 16 18:02:24 waecs apparmor.systemd[1534]: Skipping profile in /etc/apparmor.d/disable: usr.sbin.n>
May 16 18:02:24 waecs apparmor.systemd[1535]: Skipping profile in /etc/apparmor.d/disable: usr.sbin.r>
May 16 18:02:24 waecs systemd[1]: Finished Load AppArmor profiles.
lines 1-15/15 (END)
```

Disable TCP timestamp.

$ sudo nano /etc/sysctl.conf

Set *net.ipv4.tcp_timestamps=0*. This setting controls whether TCP timestamps are enabled or disabled. Setting it to 0 disables TCP timestamps, which can be useful in certain security configurations or environments.

```
admin@waecs: ~
File  Edit  View  Search  Terminal  Help
  GNU nano 6.2                    /etc/sysctl.conf *
net.ipv4.conf.all.send_redirects = 0
#
# Do not accept IP source route packets (we are not a router)
#net.ipv4.conf.all.accept_source_route = 0
#net.ipv6.conf.all.accept_source_route = 0
#
# Log Martian Packets
net.ipv4.conf.all.log_martians = 1
#

###################################################################
# Magic system request Key
# 0=disable, 1=enable all, >1 bitmask of sysrq functions
# See https://www.kernel.org/doc/html/latest/admin-guide/sysrq.html
# for what other values do
#kernel.sysrq=438

net.ipv4.tcp_timestamps=0



^G Help      ^O Write Out  ^W Where Is   ^K Cut       ^T Execute    ^C Location
^X Exit      ^R Read File  ^\ Replace    ^U Paste     ^J Justify    ^/ Go To Line
```

Systemctl Hardening

$ sudo nano /etc/sysctl.conf

This command configures how the system responds to incoming traffic and defends it against various threats, including faulty packets and TCP SYN floods.

Uncomment the file as per the image below.

```
admin@waecs: ~
File  Edit  View  Search  Terminal  Help
  GNU nano 6.2                                  /etc/sysctl.conf *
# prevent some spoofing attacks
net.ipv4.conf.default.rp_filter=1
net.ipv4.conf.all.rp_filter=1

# Uncomment the next line to enable TCP/IP SYN cookies
# See http://lwn.net/Articles/277146/
# Note: This may impact IPv6 TCP sessions too
net.ipv4.tcp_syncookies=1

# Uncomment the next line to enable packet forwarding for IPv4
#net.ipv4.ip_forward=1

# Uncomment the next line to enable packet forwarding for IPv6
#  Enabling this option disables Stateless Address Autoconfiguration
#  based on Router Advertisements for this host
#net.ipv6.conf.all.forwarding=1


###################################################################
# Additional settings - these settings can improve the network
# security of the host and prevent against some network attacks
# including spoofing attacks and man in the middle attacks through
# redirection. Some network environments, however, require that these
# settings are disabled so review and enable them as needed.
#
# Do not accept ICMP redirects (prevent MITM attacks)
net.ipv4.conf.all.accept_redirects = 0
net.ipv6.conf.all.accept_redirects = 0
# _or_
# Accept ICMP redirects only for gateways listed in our default
# gateway list (enabled by default)
# net.ipv4.conf.all.secure_redirects = 1
#
# Do not send ICMP redirects (we are not a router)
net.ipv4.conf.all.send_redirects = 0
#

^G Help      ^O Write Out   ^W Where Is    ^K Cut       ^T Execute   ^C Location  M-U Undo
^X Exit      ^R Read File   ^\ Replace     ^U Paste     ^J Justify   ^/ Go To Line M-E Redo
```

Server Header Information

$ sudo nano /etc/apache2/apache2.conf

To minimize or disable the information disclosed in the Server HTTP response header on an Ubuntu server, set:

ServerTokens Prod

ServerSignature Off

Save file, exit and restart apache service : *sudo systemctl restart apache2*

```
admin@waecs: /etc
File  Edit  View  Search  Terminal  Help
  GNU nano 6.2                    /etc/apache2/apache2.conf
LogFormat "%{User-agent}i" agent

# Include of directories ignores editors' and dpkg's backup files,
# see README.Debian for details.

# Include generic snippets of statements
IncludeOptional conf-enabled/*.conf

# Include the virtual host configurations:
IncludeOptional sites-enabled/*.conf

# vim: syntax=apache ts=4 sw=4 sts=4 sr noet

ServerTokens Prod
ServerSignature Off
```

Additional Security Implementation

Secure Remote Access

Installation of VPN

$ sudo apt-get install OpenVPN

This command is used to install OpenVPN (an open-source package) on the Linux ubuntu server. VPN on Ubuntu cloud servers enhances security, access control, and remote management, making it a crucial part of a robust cloud security strategy

```
admin@waecs: ~
File  Edit  View  Search  Terminal  Help
admin@waecs:~$ sudo apt-get install openvpn
[sudo] password for admin:
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
openvpn is already the newest version (2.5.9-0ubuntu0.22.04.2).
0 upgraded, 0 newly installed, 0 to remove and 0 not upgraded.
admin@waecs:~$
```

$ sudo apt-get install OpenVPN

This command is used to verify the installed version of the OpenVPN package.

```
File  Edit  View  Search  Terminal  Help
admin@waecs:~$ openvpn --version
OpenVPN 2.5.9 x86_64-pc-linux-gnu [SSL (OpenSSL)] [LZO] [LZ4] [EPOLL] [PKCS11] [MH/PKTINFO]
 [AEAD] built on Sep 29 2023
library versions: OpenSSL 3.0.2 15 Mar 2022, LZO 2.10
Originally developed by James Yonan
Copyright (C) 2002-2022 OpenVPN Inc <sales@openvpn.net>
```

Installation of Anti-virus

ClamAV Installation

$ sudo apt install clamav clamav-daemon

This command is used to install the Clam AntiVirus (ClamAV) software, which is a popular open-source antivirus and anti-malware tool (Contributor, 2022).

```
admin@waecs: ~
File  Edit  View  Search  Terminal  Help
admin@waecs:~$ sudo apt install clamav clamav-daemon
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following additional packages will be installed:
  clamav-base clamav-freshclam clamdscan libclamav9 libtfm1
Suggested packages:
  libclamunrar clamav-docs daemon libclamunrar9
The following NEW packages will be installed:
  clamav clamav-base clamav-daemon clamav-freshclam clamdscan libclamav9 libtfm1
0 upgraded, 7 newly installed, 0 to remove and 0 not upgraded.
Need to get 1,498 kB of archives.
After this operation, 5,138 kB of additional disk space will be used.
Do you want to continue? [Y/n] y
Get:1 http://gb.archive.ubuntu.com/ubuntu jammy-updates/main amd64 clamav-base all 0.103.11
+dfsg-0ubuntu0.22.04.1 [79.3 kB]
Get:2 http://gb.archive.ubuntu.com/ubuntu jammy/main amd64 libtfm1 amd64 0.13-4build2 [65.9
 kB]
Get:3 http://gb.archive.ubuntu.com/ubuntu jammy-updates/main amd64 libclamav9 amd64 0.103.1
1+dfsg-0ubuntu0.22.04.1 [880 kB]
Get:4 http://gb.archive.ubuntu.com/ubuntu jammy-updates/main amd64 clamav-freshclam amd64 0
.103.11+dfsg-0ubuntu0.22.04.1 [70.6 kB]
Get:5 http://gb.archive.ubuntu.com/ubuntu jammy-updates/main amd64 clamav amd64 0.103.11+df
sg-0ubuntu0.22.04.1 [134 kB]
```

$ clamscan -V

The output displays the ClamAV antivirus software version.

```
admin@waecs: ~
File  Edit  View  Search  Terminal  Help
admin@waecs:~$ clamscan -V
ClamAV 0.103.11/27280/Sun May 19 08:24:10 2024
admin@waecs:~$
```

$ clamscan

The output shows the results of running the "clamscan" command, which scans files using the ClamAV antivirus software. The scan found no infected files on the system, which appears to be the admin user's home directory.

```
File  Edit  View  Search  Terminal  Help
admin@waecs:~$ clamscan
/home/admin/.bash_history: OK
/home/admin/.profile: OK
/home/admin/v3.3.0.zip: OK
/home/admin/.lesshst: OK
/home/admin/.viminfo: OK
/home/admin/.sudo_as_admin_successful: Empty file
/home/admin/.bash_logout: OK
/home/admin/httpd-2.4.59.tar.gz: OK
/home/admin/.wget-hsts: OK
/home/admin/.bashrc: OK

----------- SCAN SUMMARY -----------
Known viruses: 8693013
Engine version: 0.103.11
Scanned directories: 1
Scanned files: 9
Infected files: 0
Data scanned: 14.14 MB
Data read: 9.82 MB (ratio 1.44:1)
Time: 29.802 sec (0 m 29 s)
Start Date: 2024:05:19 14:29:40
End Date:   2024:05:19 14:30:09
admin@waecs:~$
```

Demonstration of security

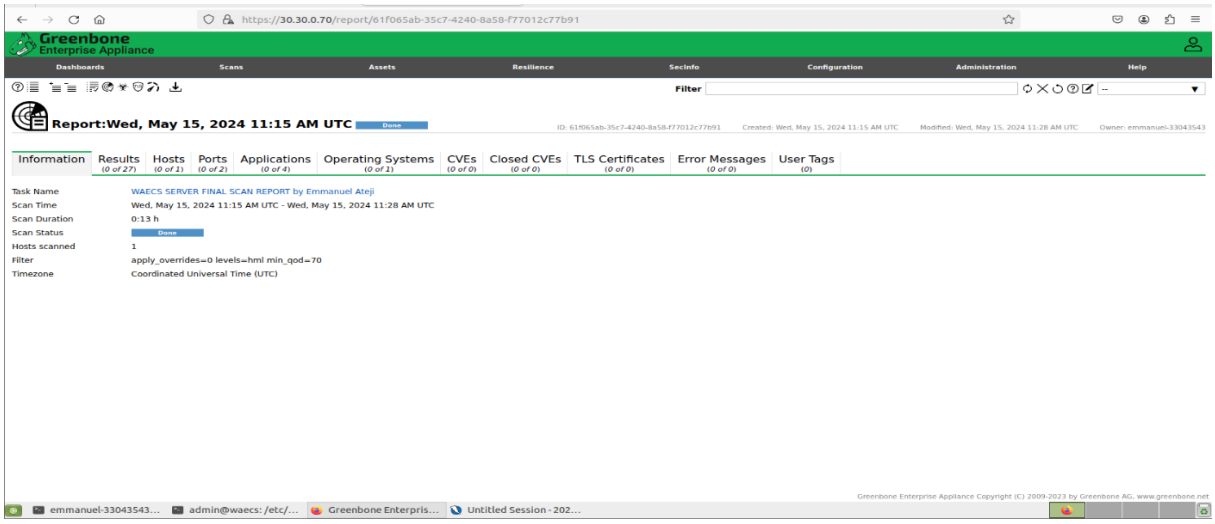
The SoftCorp cloud server has undergone a comprehensive set of vulnerability scans using industry-standard tools, including Greenbone (OpenVAS), NEXPOSE, OWASP ZAP, Nikto, and NESSUS. The scan results show no critical or high-severity vulnerabilities were detected, and the default credentials issue has been resolved. The Apache HTTP Server has also been patched and all identified vulnerabilities have been addressed. The OpenSSH server no longer supports weak MAC algorithms. Vulnerabilities like the phpinfo() file has been removed, and the jQuery library has been updated to the latest secure version. The server no longer leaks version information via the "Server" HTTP response header. Manual testing and code review confirmed the effectiveness of the implemented security measures. The server has achieved a significantly improved security posture, reducing the risk of unauthorized access, data breaches, and other security incidents. However, the lack of Anti-CSRF protection remains an area for improvement.

SoftCorp is committed to addressing this issue in future iterations of the server's development and deployment process.

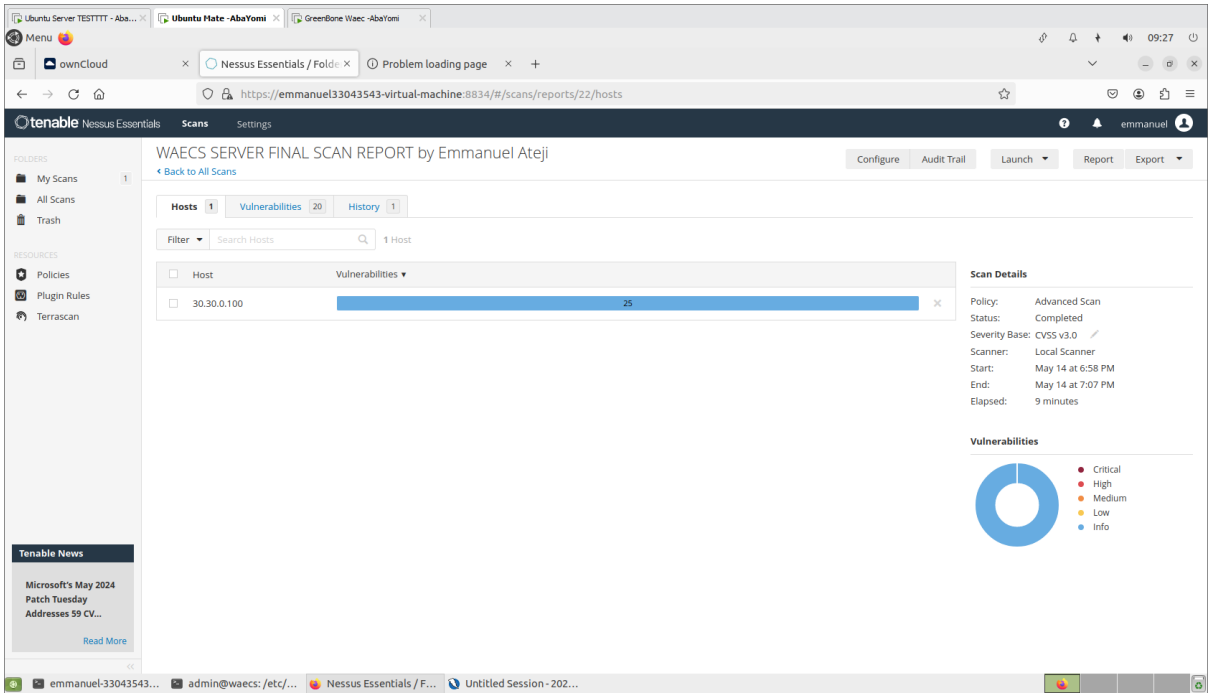
Overall, the implemented security measures have brought the cloud server into alignment with industry best practices and standards, providing a strong foundation for secure operations in a DevOps environment.

Below, are the results of the final scans taken. See appendix for the full report.

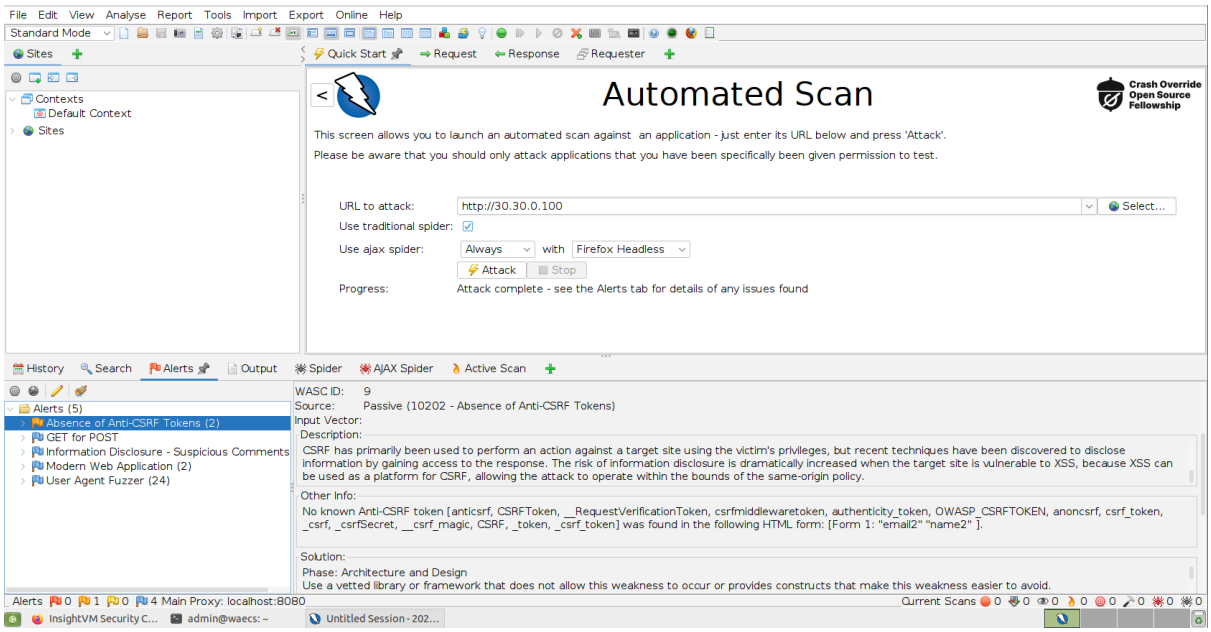
Green bone (OpenVAS) Final Scan



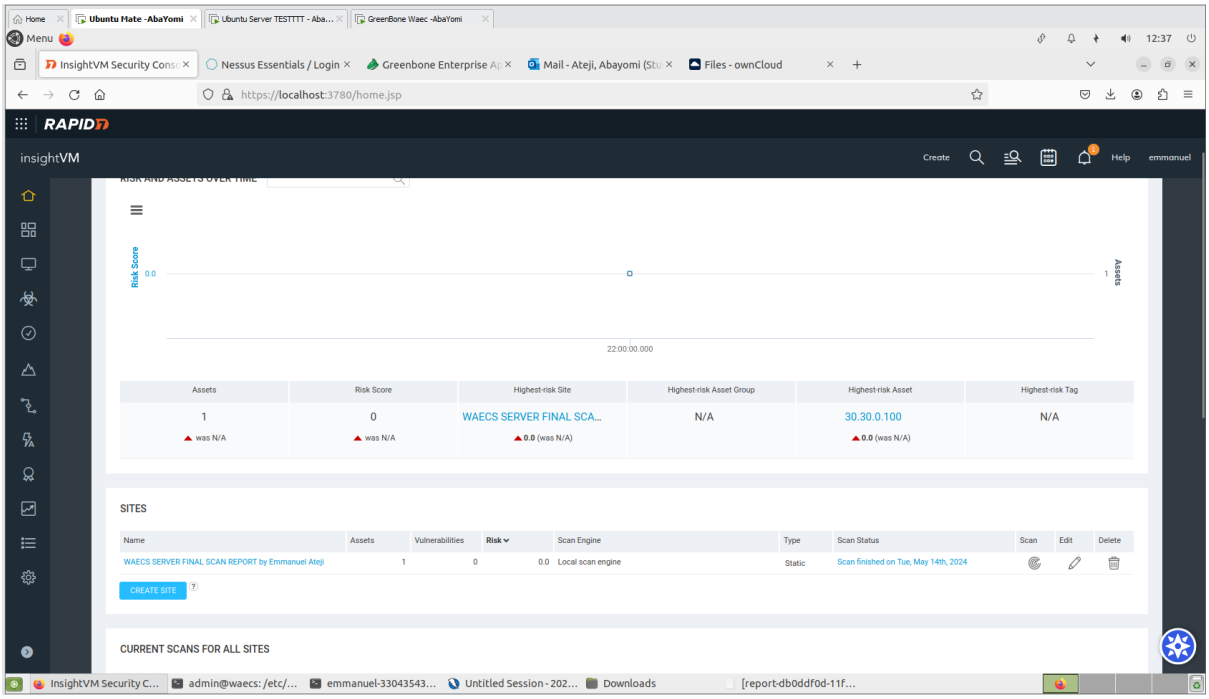
Nessus Final Scan



OWASP ZAP Final Scan



NEXPOSE Final Scan



NIKTO Final Scan

```
emmanuel-33043543@emmanuel33043543-virtual-machine: ~/Desktop
File  Edit  View  Search  Terminal  Help
emmanuel-33043543@emmanuel33043543-virtual-machine:~/Desktop$ nikto -h 30.30.0.100
- Nikto v2.1.5
---------------------------------------------------------------------------
+ Target IP:          30.30.0.100
+ Target Hostname:    30.30.0.100
+ Target Port:        80
+ Start Time:         2024-05-19 15:42:36 (GMT1)
---------------------------------------------------------------------------
+ Server: Apache
+ The anti-clickjacking X-Frame-Options header is not present.
+ Uncommon header 'content-security-policy' found, with contents: default-src 'self';script-src
 'self';style-src 'self';img-src 'self';form-action 'self';frame-ancestors 'self';
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ 6544 items checked: 0 error(s) and 2 item(s) reported on remote host
+ End Time:           2024-05-19 15:43:24 (GMT1) (48 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
emmanuel-33043543@emmanuel33043543-virtual-machine:~/Desktop$
```

Conclusion

In conclusion, SoftCorp's comprehensive security assessment and hardening of its cloud server have significantly enhanced its security posture, addressing critical vulnerabilities and aligning the server with industry best practices. The implemented security measures have prepared the server for secure deployment in a DevOps environment, with a commitment to continuous improvement and addressing the remaining Anti-CSRF protection issue.

References

Aldossary, S., & Allen, W. (2016). Data security, privacy, availability and integrity in cloud Computing: Issues and current solutions. *International Journal of Advanced Computer Science and Applications/International Journal of Advanced Computer Science & Applications*, *7*(4). https://doi.org/10.14569/ijacsa.2016.070464

Apache upgrade to 2.4.58 on Ubuntu 22.04. (n.d.). Server Fault. https://serverfault.com/questions/1151794/apache-upgrade-to-2-4-58-on-ubuntu-22-04

Basu, S., Bardhan, A., Gupta, K., Saha, P., Pal, M., Bose, M., Basu, K., Chaudhury, S., & Sarkar, P. (2018). Cloud computing security challenges & solutions-A survey. *IEEE 8th Annual Computing and Communication Workshop and Conference (CCWC)*. https://doi.org/10.1109/ccwc.2018.8301700

Bou-Harb, E., Debbabi, M., & Assi, C. (2014). Cyber Scanning: A comprehensive survey. *IEEE Communications Surveys and Tutorials/IEEE Communications Surveys and Tutorials*, *16*(3), 1496–1519. https://doi.org/10.1109/surv.2013.102913.00020

Buckbee, M. (2022, January 19). What is a Port Scanner and How Does it Work? *Varonis*. https://www.varonis.com/blog/port-scanning-techniques

Callegati, F., Cerroni, W., & Ramilli, M. (2009). Man-in-the-Middle attack to the HTTPS protocol. *IEEE Security & Privacy*, *7*(1), 78–81. https://doi.org/10.1109/msp.2009.12

Cleartext Transmission | GuardRails. (2023, February 18). https://docs.guardrails.io/docs/vulnerability-classes/insecure-network-communication/cleartext-transmission

Compiling and Installing - Apache HTTP Server Version 2.4. (n.d.). https://httpd.apache.org/docs/2.4/install.html#ubuntu

Conti, M., Dragoni, N., & Lesyk, V. (2016). A survey of Man in the middle attacks. *IEEE Communications Surveys and Tutorials/IEEE Communications Surveys and Tutorials*, *18*(3), 2027–2051. https://doi.org/10.1109/comst.2016.2548426

Contributor, I. H. (2022, March 1). *How to install ClamAV on Ubuntu*. InMotion Hosting Support Center. https://www.inmotionhosting.com/support/security/install-clamav-on-ubuntu/

Coppolino, L., D'Antonio, S., Mazzeo, G., & Romano, L. (2017). Cloud security: Emerging threats and current solutions. *Computers & Electrical Engineering*, *59*, 126–140. https://doi.org/10.1016/j.compeleceng.2016.03.004

Fernandes, D. a. B., Soares, L. F. B., Gomes, J. V., Freire, M. M., & Inácio, P. R. M. (2013). Security issues in cloud environments: a survey. *International Journal of Information Security*, *13*(2), 113–170. https://doi.org/10.1007/s10207-013-0208-7

Goyal, S. (2014). Public vs Private vs Hybrid vs Community - Cloud Computing: A Critical Review. *International Journal of Computer Network and Information Security*, *6*(3), 20–29. https://doi.org/10.5815/ijcnis.2014.03.03

Grance, P. M. M. T. (2018, November 10). *The NIST definition of cloud Computing*. NIST. https://www.nist.gov/publications/nist-definition-cloud-computing

Gupta, S., & Gupta, B. B. (2015). Cross-Site Scripting (XSS) attacks and defense mechanisms: classification and state-of-the-art. *International Journal of System Assurance Engineering and Management*, *8*(S1), 512–530. https://doi.org/10.1007/s13198-015-0376-0

Halfond, W. G. J., Viegas, J., & Orso, A. (2006). *A classification of SQL injection attacks and countermeasures*. https://www.semanticscholar.org/paper/A-Classification-of-SQL-Injection-Attacks-and-Halfond-Viegas/81a502b52485e52713ccab6d260f15871c2acdcb?utm_source=direct_link

Hardening SSH MAC algorithms - Red Hat Customer Portal. (2019, January 3). Red Hat Customer Portal. https://access.redhat.com/discussions/3121481

IMohaidat, A., & Al-Helali, D. (2024). Web Vulnerability scanning Tools: A comprehensive overview, selection guidance, and cyber security recommendations. *International Journal of Research Studies in Computer Science and Engineering*, *10*(1), 8–15. https://doi.org/10.20431/2349-4859.1001002

Inc, C. (2022, July 7). *Hardening Apache web server and PHP*. https://techdocs.broadcom.com/us/en/symantec-security-software/endpoint-security-and-management/data-center-security-(dcs)/6-9-2/configuring-v127944871-d3608e167568/hardening-apache-web-server-and-php-v127946718-d3608e173015.html

Jouini, M., & Rabai, L. B. A. (2019). A security framework for secure cloud computing environments. In *IGI Global eBooks* (pp. 249–263). https://doi.org/10.4018/978-1-5225-8176-5.ch011

Kandias, M., Mylonas, A., Virvilis, N., Theoharidou, M., & Gritzalis, D. (2010). An insider threat prediction model. In *Lecture notes in computer science* (pp. 26–37). https://doi.org/10.1007/978-3-642-15152-1_3

Krishnamurthy, M., Seagren, E. S., Alder, R., Bayles, A. W., Burke, J., Carter, S., & Faskha, E. (2008). Apache web Server hardening. In *Elsevier eBooks* (pp. 383–401). https://doi.org/10.1016/b978-159749207-2.50012-9

Liu, F., Tong, J., Mao, J., Bohn, R., Messina, J., Badger, L., Leaf, D., & National Institute of Standards and Technology. (2011). NIST Cloud Computing Reference Architecture. In *NIST Special Publication 500-292*. National Institute of Standards and Technology. https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication500-292.pdf

Modi, C., Patel, D., Borisaniya, B., Patel, H., Patel, A., & Rajarajan, M. (2013). A survey of intrusion detection techniques in Cloud. *Journal of Network and Computer Applications*, *36*(1), 42–57. https://doi.org/10.1016/j.jnca.2012.05.003

National Institute of Standards and Technology & National Institute of Standards and Technology. (2013, May 5). *NIST Cloud Computing Security Reference Architecture*. https://csrc.nist.gov/pubs/sp/500/299/ipd

Osanaiye, O., Choo, K. R., & Dlodlo, M. (2016). *Distributed denial of service (DDoS) resilience in cloud: Review and conceptual cloud DDoS mitigation framework*. https://www.semanticscholar.org/paper/Distributed-denial-of-service-(DDoS)-resilience-in-Osanaiye-Choo/cd24e4d061640a88b0605f74bf56d9c4c5079546?utm_source=direct_link

OWASP ModSecurity | OWASP Foundation. (2024, January). https://owasp.org/www-project-modsecurity/

Rahul, & Rahul. (2024, February 2). *How to disable HTTP methods in Apache*. TecAdmin. https://tecadmin.net/how-to-disable-http-methods-in-apache/

Salem, M. B., Hershkop, S., & Stolfo, S. J. (2008). A survey of insider attack detection research. In *Advances in information security* (pp. 69–90). https://doi.org/10.1007/978-0-387-77322-3_5

Scarfone, K. A., Souppaya, M. P., Cody, A., & Orebaugh, A. D. (2008). *Technical guide to information security testing and assessment.* https://doi.org/10.6028/nist.sp.800-115

Singh, S., Sharma, P. K., Yoon, B., Shojafar, M., Cho, G. H., & Ra, I. (2020). Convergence of blockchain and artificial intelligence in IoT network for the sustainable smart city. *Sustainable Cities and Society*, *63*, 102364. https://doi.org/10.1016/j.scs.2020.102364

Somani, G., Gaur, M. S., Sanghi, D., Conti, M., & Buyya, R. (2017). DDoS attacks in cloud computing: Issues, taxonomy, and future directions. *Computer Communications*, *107*, 30–48. https://doi.org/10.1016/j.comcom.2017.03.010

Toyin, S. (2023). COMPARATIVE ANALYSIS OF SECURITY VULNERABILITY SCANNERS (NESSUS AND OpenVAS) IN CLOUD ENVIRONMENT. *ResearchGate*. https://www.researchgate.net/publication/374152285_COMPARATIVE_ANALYSIS_OF_SECURITY_VULNERABILITY_SCANNERS_NESSUS_AND_OpenVAS_IN_CLOUD_ENVIRONMENT

Ubuntu Server documentation | Ubuntu. (n.d.). Ubuntu. https://help.ubuntu.com/lts/serverguide/automatic-updates.html

Upgrades - Community Help Wiki. (n.d.). https://help.ubuntu.com/community/Upgrades

Weidman, G. (2014, May 22). *Penetration Testing: A Hands-On Introduction to Hacking*. Goodreads. https://www.goodreads.com/book/show/18771903-penetration-testing

What is the Cloud Controls Matrix (CCM)? | CSA. (2020, October 16). https://cloudsecurityalliance.org/blog/2020/10/16/what-is-the-cloud-controls-matrix-ccm

Wodarek, L. (2022, September 14). *Updating from Old and Outdated jQuery without Becoming a Rage Monster*. CQL. https://www.cqlcorp.com/insights/updating-from-old-and-outdated-jquery-without-becoming-a-rage-monster/

Appendix

INITIAL SCAN RESULTS

Greenbone (OpenVAS) Initial Sc

NESSUS Initial Scan Result.pdf

OWASP ZAP Intial Scan Result.pdf

NEXPOSE Initial Scan Result.pdf

Nikto Initial Scan.PNG

FINAL SCAN RESULTS

Greenbone (OpenVAS) FINAL Sc

NESSUS WAECS SERVER FINAL SCAN

OWASP ZAP Final Scan.pdf

NEXPOSE FINAL SCAN.pdf

FINAL NIKTO SCAN.PNG